

CCNA 200-301 Ağ Güvenliği Kavramları

- Mevcut Siber Güvenlik Durumu
- Tehdit Aktörleri
- Tehdit Aktörü Araçları
- Kötü Amaçlı Yazılım
- Ortak Ağ Saldırıları
- IP Güvenlik Açıkları ve Tehditleri
- TCP ve UDP Güvenlik Açıkları
- IP Servisleri
- En İyi Ağ Güvenliği Uygulamaları
- Kriptografi
- VPN Teknolojisi
- VPN Türleri
- IPsec

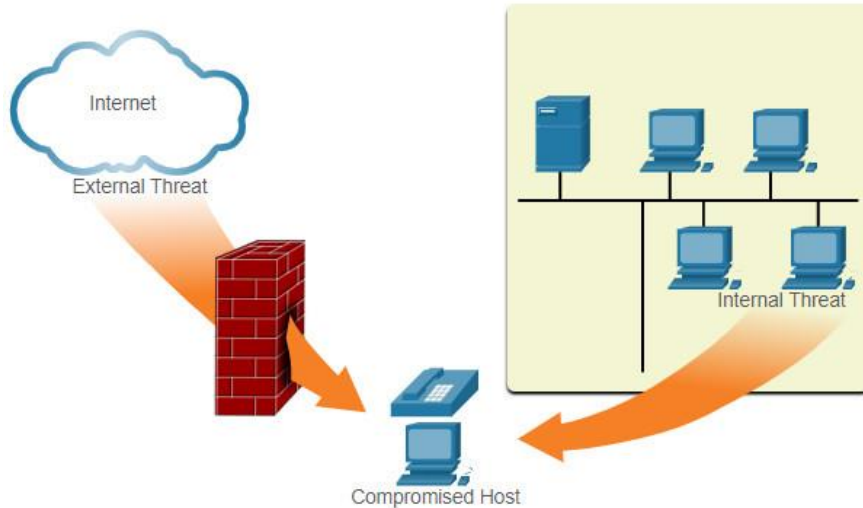
Mevcut Siber Güvenlik Durumu

- Siber suçlular artık kritik altyapı ve sistemleri çökertmek için gerekli uzmanlığa ve araçlara sahipler. Araçları ve teknikleri geliştirmeye devam ediyor.
- Güvenli bir ağın korunması ağ kullanıcılarının güvenliğini sağlar ve ticari çıkarları korur. Tüm kullanıcılar tablodaki güvenlik terimlerinin farkında olmalıdır.

Güvenlik Terimleri	Açıklama
Assests (Varlıklar)	Bir varlık, kuruluş için değerli bir şeydir. İnsanları, ekipmanı, kaynakları ve verileri içerir.
Vulnerability (Güvenlik Açığı)	Güvenlik açığı, bir sistemdeki veya tasarımındaki bir tehdit tarafından kullanılabilir bir zayıflıktır.
Threat (Tehdit)	Tehdit, bir şirketin varlıkları, verileri veya ağ işlevselliği için potansiyel bir tehlikedir.
Exploit (Sömürmek/İstismar)	Bir istismar, güvenlik açığından yararlanan bir mekanizmadır.
Mitigation (Hafifletme)	Etki azaltma, potansiyel bir tehdit veya riskin olasılığını veya şiddetini azaltan karşı önlemdir. Ağ güvenliği çoklu azaltma tekniklerini içerir.
Risk	Risk, bir kuruluşu olumsuz etkilemek amacıyla bir varlığın kırılganlığından yararlanma tehdididir. Risk, bir olayın meydana gelme olasılığı ve sonuçları kullanılarak ölçülür.

Ağ Saldırılarının Vektörleri

- Saldırı vektörü, bir tehdit aktörünün sunucuya, bilgisayara veya ağa erişebileceği bir yoldur. Saldırı vektörleri şekilde gösterildiği gibi şirket ağının içinden veya dışından gelir.
- İç tehditler, dış tehditlere göre daha fazla zarar verme potansiyeline sahiptir, çünkü iç kullanıcılar binaya ve altyapı cihazlarına doğrudan erişime sahiptir.



Data Loss (Veri Kaybı)

Veri kaybı veya veri sızması, verilerin kasıtlı veya kasıtsız olarak kaybedilmesi, çalınması veya dış dünyaya sızdırılmasıdır. Veri kaybı aşağıdakilere neden olabilir:

- Marka hasarı ve itibar kaybı
- Rekabet avantajı kaybı
- Müşteri kaybı
- Gelir kaybı
- Para cezaları ve hukuki cezalarla sonuçlanan dava / yasal işlem
- Etkilenen tarafları bilgilendirmek ve ihlalden kurtulmak için önemli maliyet ve çaba

Ağ güvenliği uzmanları kuruluşun verilerini korumalıdır. Stratejik, operasyonel ve taktik önlemleri birleştiren çeşitli Veri Kaybını Önleme (DLP – Data Loss Prevention) kontrolleri uygulanmalıdır. (KVKK)

Veri Kaybı Vektörleri	Açıklama
E-posta / Sosyal Ağ	Ele geçirilen e-posta veya IM mesajları yakalanabilir ve gizli bilgiler ortaya çıkartılabilir.
Şifrelenmemiş Cihazlar	Verileri bir şifreleme algoritması kullanarak saklanmazsa, hırsız değerli gizli verileri alabilir.
Bulut Depolama Cihazları	Güvenlik ayarları zayıf olduğundan bulut erişimin güvenliği ihlal edilirse hassas veriler kaybedilebilir.
Çıkarılabilir Medya	Bir risk, bir çalışanın USB sürücüsüne izinsiz veri aktarımı yapabilmesidir. Diğer bir risk, değerli kurumsal veriler içeren bir USB sürücüsünün kaybolabilmesidir.
Basılı kopya	Gizli veriler artık gerekli olmadığında parçalanmalıdır.
Uygunsuz Erişim Kontrolü	Zayıf şifreler kurumsal verilere kolay erişim sağlayan bir tehdit aktörü sağlayabilir.

Tehdit Aktörleri

- Hacker bir tehdit aktörünü tanımlamak için kullanılan yaygın bir terimdir.

Hacker Tipleri	Açıklama
White Hat Hackers (Beyaz Şapkalı Hackerlar)	Bunlar programlama becerilerini iyi, etik ve yasal amaçlar için kullanan etik hackerlardır. Güvenlik açıklarından yararlanılmadan önce düzeltmeleri için geliştiricilere bildirilir.
Gray Hat Hackers (Gri Şapkalı Hackerlar)	Bunlar, suç işleyen ve tartışmasız etik olmayan şeyler yapan, ancak kişisel kazanç ya da hasara yol açmayan bireylerdir. Gri şapka korsanları, ağlarını tehlikeye attıktan sonra etkilenen kuruluşa bir güvenlik açığını açıklayabilir.
Black Hat Hackers (Siyah Şapkalı Hackerlar)	Bunlar, kişisel kazanç veya ağlara saldırmak gibi kötü amaçlı nedenlerle bilgisayar ve ağ güvenliğinden ödün veren etik dışı suçlulardır.

Saldırganların Dönüşümü

Tabloda modern bilgisayar korsanlığı terimleri ve her birinin kısa bir açıklaması gösterilmektedir.

Hacking Terimi	Açıklama
Script Kiddies (Kod Çocukları)	Bunlar, zarar vermek için mevcut komut dosyalarını, araçları ve istismarları çalıştıran gençler veya deneyimsiz bilgisayar korsanlarıdır, ancak genellikle para için değil merak veya heyecan için yaparlar.
Vulnerability Broker (Güvenlik Açığı Aracısı)	Bunlar genellikle istismarları keşfetmeye ve bunları bazen ödüller için satıcılara bildirmeye çalışan gri şapka korsanlarıdır.
Hacktivists (Haktivistler)	Bunlar, makaleleri, videoları yayınlayarak, hassas bilgileri sızdırıp ağ saldırıları gerçekleştirerek kuruluşları veya hükümetleri kamuya açık olarak protesto eden gri şapka korsanlarıdır. Wikileaks (Julian Assange- Amerikanın Irakta Sivilleri katlettiği görüntüler)
Cyber Criminals (Siber Suçlular)	Bunlar kendi hesabına çalışan veya büyük siber suç örgütleri için çalışan siyah şapkalı korsanlardır.
State-Sponsored (Devlet Destekli Hacker)	Bunlar, hükümet sırlarını çalan, istihbarat toplayan ve sabotaj ağlarını kullanan beyaz şapka veya siyah şapkalı korsanlardır. Hedefleri yabancı hükümetlerdir, terörist gruplar ve şirketlerdir. Dünyadaki çoğu ülke devlet destekli bilgisayar korsanlığını bir dereceye kadar kullanıyor.

Cyber Criminals (Siber Suçlular)

Siber suçluların tüketicilerden ve işletmelerden milyarlarca dolar çaldığı tahmin edilmektedir. Siber suçlular, saldırı araç kitleri, sıfır gün istismar kodu, botnet hizmetleri, bankacılık Truva atları, keyloggerlar ve çok daha fazlasını satın aldıkları, sattıkları ve ticaret yaptıkları bir yeraltı ekonomisinde (Deep/Dark Web) çalışırlar. Ayrıca çaldıkları özel bilgileri ve fikri mülkleri alıp satarlar. Siber suçlular küçük işletmeleri ve tüketicileri, büyük işletmeleri ve tüm sektörleri hedef alır. Yani herkesi.

Hacktivists (Haktivistler)

Haktivist gruplara iki örnek Anonymous ve Suriye Elektronik Ordusu'dur. Çoğu haktivist grup iyi örgütlenmiş olsa da, hükümetler ve işletmeler için önemli sorunlara neden olabilirler. Haktivistler, oldukça basit, serbestçe kullanılabilen araçlara güvenme eğilimindedir.

State-Sponsored Hackers (Devlet Destekli Hackerlar)

Devlet destekli bilgisayar korsanları, genellikle sıfır gün güvenlik (zero day) açıkları adı verilen önceden keşfedilmemiş yazılım güvenlik açıklarını kullanarak gelişmiş, özelleştirilmiş saldırı kodu oluşturur. Devlet destekli bir saldırı örneği, İran'ın nükleer zenginleştirme yeteneklerine zarar vermek için oluşturulan Stuxnet kötü amaçlı yazılımı.

Tehdit Aktörü Araçları

Saldırı Araçlarına Giriş

Bir güvenlik açığından yararlanmak için bir tehdit aktörünün bir tekniği veya aracı olmalıdır. Yıllar geçtikçe saldırı araçları daha sofistike ve yüksek derecede otomatik hale geldi. Bu yeni araçlar kullanmak için daha az teknik bilgi gerektirir.

Güvenlik Araçlarının Gelişimi

Tabloda yaygın sızma testi araçlarının kategorileri vurgulanmaktadır. Bazı araçların beyaz şapkalı ve siyah şapkalı hackerlar tarafından nasıl kullanıldığına dikkat edin. Yeni araçlar her zaman geliştirildiği için listenin kapsamlı olduğunu unutmayın.

Penetration Testing Tool (Penetrasyon Test Aracı)	Açıklama
Password Crackers (Parola Kırıcılar)	Parola kırma araçlarına genellikle parola kurtarma araçları denir ve bir parola kırmak veya kurtarmak için kullanılabilir. Şifre kırıcılar, şifreyi kırmak için tekrar tekrar tahminler yapar. Parola kırma araçlarına örnek olarak John The Ripper, Ophcrack, L0phtCrack, THC Hydra, Rainbow Crack ve Medusa verilebilir.
Wireless Hacking Tools (Kablosuz Ağ Kırma Araçları)	Kablosuz hackleme araçları, güvenlik açıklarını tespit etmek için kasıtlı olarak kablosuz bir ağa hacklemek için kullanılır. Kablosuz hackleme araçlarına örnek olarak Aircrack-ng, Kismet, InSSIDer, Firesheep ve WiStumbler verilebilir.
Network Scanning and Hacking Tools (Ağ Tarama ve Hackleme Araçları)	Ağ tarama araçları, açık TCP veya UDP bağlantı noktaları için ağ aygıtlarını, sunucuları ve ana bilgisayarları araştırmak için kullanılır. Tarama araçlarına örnek olarak Nmap, SuperScan, Angry IP Scanner ve NetScanTools verilebilir.
Packet Crafting Tools (Paket Üretim Araçları)	Bu araçlar, özel hazırlanmış sahte paketler kullanarak bir güvenlik duvarının sağlamlığını araştırmak ve test etmek için kullanılır. Örnekler arasında Hping, Scapy, Socat, Yersinia, Netcat, Nping ve Nemesis sayılabilir.
Packet Sniffers (Paket Koklayıcılar)	Bu araçlar, geleneksel Ethernet LAN'lar veya WLAN'lar içindeki paketleri yakalamak ve analiz etmek için kullanılır. Araçlar arasında Wireshark, Tcpdump, Ettercap, Dsniff, EtherApe, Paros, Fiddler, Ratproxy ve SSLstrip bulunur.

Penetration Testing Tool (Penetrasyon Test Aracı)	Açıklama
Rootkit Detectors (Rootkit Dedektörleri)	Bu, yüklü root kitlerini tespit etmek için beyaz şapkalar tarafından kullanılan bir dizin ve dosya bütünlüğü denetleyicisidir. Örnek araçlar arasında AIDE, Netfilter ve PF: OpenBSD Paket Filtresi bulunur.
Fuzzers to Search Vulnerabilities (Güvenlik Açığı Tespit Araçları)	Fuzzers, tehdit aktörleri tarafından bir bilgisayarın güvenlik açıklarını keşfetmek için kullanılan araçlardır. Örnekleri arasında Skipfish, Wapiti ve W3af bulunur.
Forensic Tool (Adli Araçlar)	Bu araçlar, beyaz şapkalı korsanlar tarafından bir bilgisayarda var olan herhangi bir kanıt izini bulmak için kullanılır. Araç örnekleri arasında Sleuth Kit, Helix, Maltego ve Encase bulunur.
Debuggers (Hata Ayıklayıcılar)	Bu araçlar, siyah şapkalar tarafından istismarları yazarken ikili dosyaları tersine çevirmek için kullanılır. Kötü amaçlı yazılımları analiz ederken beyaz şapkalar tarafından da kullanılırlar. Hata ayıklama araçları arasında GDB, WinDbg, IDA Pro ve Immunity Debugger bulunur.
Hacking Operating Systems (Hack İşletim Sistemleri)	Bunlar, bilgisayar korsanlığı için optimize edilmiş araçlarla önceden yüklenmiş özel olarak tasarlanmış işletim sistemleridir. Özel olarak tasarlanmış bilgisayar korsanlığı işletim sistemlerine örnek olarak Kali Linux, BlackBox Linux verilebilir.
Vulnerability Exploitation Tools (Güvenlik Açığı Sömürü Araçları)	Bu araçlar, uzak bir ana bilgisayarın güvenlik saldırısına karşı savunmasız olup olmadığını belirler. Güvenlik açığından yararlanma araçlarına örnek olarak Metasploit, Core Impact, Sqlmap, Social Engineer Toolkit verilebilir.
Encryption Tools (Şifreleme Araçları)	Şifreleme araçları, şifrelenmiş verilere yetkisiz erişimi önlemek amacıyla verileri kodlamak için algoritma şemaları kullanır. Bu araçlara örnek olarak VeraCrypt, CipherShed, OpenSSH, OpenSSL, Tor, OpenVPN ve Stunnel verilebilir.
Vulnerability Scanners (Güvenlik Açığı Tarayıcıları)	Bu araçlar, açık bağlantı noktalarını tanımlamak için bir ağı veya sistemi tarar. Bilinen güvenlik açıklarını taramak ve VM'leri, BYOD aygıtlarını ve istemci veri tabanlarını taramak için de kullanılabilirler. Araç örnekleri Nipper, Core Impact, Nessus, SAINT, OpenVAS ve Netsparker.

Atak Saldırı Çeşitleri

Atak Çeşitleri	Açıklama
Eavesdropping Attack (Gizli Dinleme Saldırısı)	Bu, bir tehdit aktörünün ağ trafiğini yakalayıp “dinlediği” zamandır. Bu saldırı aynı zamanda koklama/sniff veya gözetleme olarak da adlandırılır.
Data Modification Attack (Veri Değişikliği Saldırısı)	Tehdit aktörleri kurumsal trafiği yakaladıysa, gönderen veya alıcı bilgisi olmadan paketteki verileri değiştirebilir.
IP Address Spoofing Attack (IP Adresi Kimlik Sahtekarlığı)	Tehdit aktörü, şirket intranetindeki geçerli bir adresten gelmiş gibi görünen bir IP paketi oluşturur.
Password-Based Attacks (Parola Tabanlı Saldırıları)	Tehdit aktörleri geçerli bir kullanıcı hesabı bulursa artık gerçek kullanıcı ile aynı haklara sahiptir. Tehdit aktörleri, diğer kullanıcıların listelerini, ağ bilgilerini, sunucu ve ağ yapılandırmalarını değiştirmek ve verileri değiştirmek, yeniden yönlendirmek veya silmek için bu geçerli hesabı kullanabilir.
Denial of Service Attack (Hizmet Reddi Saldırısı)	DoS saldırısı, bir bilgisayarın veya ağın geçerli kullanıcılar tarafından normal kullanımını önler. DoS saldırısı, aşırı yükleme nedeniyle bir kapatma gerçekleşene kadar bir bilgisayarı veya tüm ağı trafikle doldurabilir. DoS saldırısı, trafiği engelleyebilir ve bu da yetkili kullanıcılar tarafından ağ kaynaklarına erişim kaybına neden olur.
Man-in-the-Middle Attack (Ortadaki Adam Saldırısı)	Bu saldırı, tehdit aktörleri kendilerini kaynak ve hedef arasında konumlandıkları anda meydana gelir. Artık iletişimi şeffaf bir şekilde izleyebilir, yakalayabilir ve kontrol edebilirler.
Compromised-Key Attack (Güvenliği Aşılmiş Anahtar Saldırısı)	Bir tehdit aktörü gizli bir anahtar alırsa, bu anahtar güvenliği ihlal edilmiş anahtar olarak adlandırılır. Güvenliği ihlal edilmiş bir anahtar, gönderen veya alıcı saldırıdan haberdar olmadan güvenli bir iletişime erişim sağlamak için kullanılabilir.
Sniffer Attack (Sniffer Saldırısı)	Sniffer, ağ veri alışverişini okuyabilen, izleyebilen ve yakalayabilen bir uygulama veya cihazdır. Paketler şifrelenmemişse, bir dinleyici paketin içindeki verilerin tam görünümünü sağlar.

Kötü Amaçlı Yazılımlara Genel Bakış

- Artık bilgisayar korsanlarının kullandığı araçları bildiğinize göre, bu konu bilgisayar korsanlarının son cihazlara erişmek için kullandığı farklı kötü amaçlı yazılım türlerini tanıtır.
- Son cihazlar özellikle kötü amaçlı yazılım saldırılarına eğilimlidir. Kötü amaçlı yazılımları bilmek önemlidir, çünkü tehdit aktörleri güvenlik açıklarından yararlanmaya yardımcı olmak için kullanıcılara kötü amaçlı yazılım yüklemeye güvenir.

Viruses and Trojan Horses (Virüsler ve Truva Atları)

- Bilgisayar zararlı yazılımlarının ilk ve en yaygın türü virüstür. Virüsler, diğer bilgisayarlara yayılmak ve enfekte etmek için insan eylemi gerektirir.
- Virüs, kendisini bilgisayar koduna, yazılıma veya bilgisayardaki belgelere ekleyerek gizlenir. Açıldığında, virüs bilgisayarda çalışır ve bulaşır.
- Virüsler şunları yapabilir:
 - Tüm sürücülerini değiştirir, bozar, siler.
 - Bilgisayar önyükleme sorunlarına ve bozuk uygulamalara neden olabilir.
 - Tehdit aktörlerine hassas bilgiler yakalar ve gönderir.
 - Yayılmak için e-posta hesaplarına erişir ve kullanır.
 - Tehdit aktörü tarafından tetiklenene kadar uykuda olur.

Modern virüsler, tabloda listelenenler gibi belirli bir amaç için geliştirilmiştir.

Virüs Çeşitleri	Açıklama
Boot sector virüs	Virüs, önyükleme sektörüne, dosya bölümü tablosuna veya dosya sistemine saldırır.
Firmware viruses	Virüs, cihazın ürün yazılımına (bios) saldırır. (Çernobil)
Macro virüs	Virüs, MS Office makro özelliğini kötü amaçlı kullanır.
Program viruses	Virüs kendisini başka bir yürütülebilir programa ekler.
Script viruses	Virüs, komut dosyalarını yürütmek için kullanılan OS yorumlayıcısına saldırır.

Tehdit aktörleri, bilgisayarları ele geçirmek için Truva atlarını kullanır. Truva atı, yararlı görünen ancak kötü amaçlı kod taşıyan bir programdır. Truva atları genellikle bilgisayar oyunları gibi ücretsiz çevrimiçi programlarla sağlanır. Tabloda açıklandığı gibi birkaç tür Truva atı vardır.

Type of Trojan Horse	Description
----------------------	-------------

Remote access (Uzaktan Erişim)	Truva atı, yetkisiz uzaktan erişim sağlar.
Data sending (Veri Gönderme)	Truva atı, tehdit aktörüne şifreler gibi hassas veriler sağlar.
Destructive (Yıkıcı)	Truva atı dosyaları bozar veya siler.
Proxy	Truva atı, saldırı başlatmak ve diğer yasadışı faaliyetleri gerçekleştirmek için kurbanın bilgisayarını kaynak cihaz olarak kullanacaktır.
FTP	Truva atı, bilgisayardan yetkisiz dosya aktarım hizmetleri sağlar.
Security software disables (Güvenlik yazılımı devre dışı bırakıcı)	Truva atı, virüsten koruma programlarının veya güvenlik duvarlarının çalışmasını durdurur.
Denial of Service (DoS)	Truva atı ağ etkinliğini yavaşlatır ve durdurur.
Keylogger (Tuş kaydedici)	Truva atı, bir web formuna girilen tuş vuruşlarını kaydederek kredi kartı numaraları, sosyal medya giriş gibi gizli bilgileri çalmaya çalışır.

Diğer Kötü Amaçlı Yazılım Türleri

Malware	Açıklama
Adware	- Reklam yazılımı genellikle çevrimiçi yazılım indirilerek dağıtılır. - Reklam yazılımları, açılır web tarayıcı pencerelerini, yeni araç çubuklarını kullanarak veya bir web sayfasını beklenmedik bir şekilde farklı bir web sitesine yönlendirerek istenmeyen reklamlar görüntüleyebilir. - Yeni pencereler, kullanıcının kapatabildiğinden daha hızlı açılacağından, açılır pencerelerin kontrol edilmesi zor olabilir.
Ransomware	- Ransomware genellikle dosyaları şifreleyerek ve daha sonra şifre çözme anahtarı için fidye talep eden bir mesaj görüntüleyerek kişilerin dosyalarına erişimini engeller. - Güncel yedekleri olmayan kullanıcılar, dosyalarının şifresini çözmek için fidye ödemek zorundadır. - Ödeme genellikle banka havalesi veya Bitcoin gibi kripto para birimleri kullanılarak yapılır.
Rootkit	- Rootkit'ler tehdit aktörleri tarafından bir bilgisayara yönetici hesabı düzeyinde erişim elde etmek için kullanılır. - Varlıklarını gizlemek için güvenlik duvarını, antivirüs korumasını, sistem dosyalarını ve hatta OS komutlarını değiştirebildikleri için tespit edilmesi çok zordur. - Tehdit oyuncularına PC'ye erişmelerini sağlayan ve dosya yüklemelerine izin veren ve DDoS saldırısında kullanılacak yeni yazılımlar yükleyebilecekleri bir arka kapı sağlayabilirler. - Bunları kaldırmak için özel rootkit kaldırma araçları kullanılmalıdır, aksi takdirde işletim sisteminin tam olarak yeniden yüklenmesi gerekebilir.

Spyware	• Reklam yazılımı gibi, ancak kullanıcı hakkında bilgi toplamak ve kullanıcının izni olmadan tehdit aktörlerine göndermek için kullanılır. • Casus yazılımlar, tarama verilerini toplamak için düşük bir tehdit olabilir veya kişisel ve finansal bilgileri yakalamak için yüksek bir tehdit olabilir.
Worm	• Solucan, meşru yazılımdaki güvenlik açıklarından yararlanarak kullanıcı eylemleri olmadan otomatik olarak yayılan kendi kendini çoğaltan bir programdır. • Ağ, aynı güvenlik açığına sahip diğer kurbanları aramak için kullanır. • Bir solucanın amacı genellikle ağ işlemlerini yavaşlatmak veya bozmaktır.

Ortak Ağ Saldırıları

Ağ Saldırılarına Genel Bakış

- Kötü amaçlı yazılım yüklendiğinde, yük, ağla ilgili çeşitli saldırılara neden olmak için kullanılabilir.
- Saldırıları azaltmak için saldırı türlerini anlamak yararlıdır. Ağ saldırılarını kategorilere ayırarak, bireysel saldırılar yerine saldırı türlerini ele almak mümkündür.
- Ağlar aşağıdaki saldırı türlerine karşı hassastır:
 - Keşif Saldırıları
 - Erişim Saldırıları
 - DoS Saldırıları

Keşif Saldırıları

- Keşif bilgi toplamaktır.
- Tehdit aktörleri, sistemlerin, hizmetlerin veya güvenlik açıklarının yetkisiz olarak keşfedilmesi ve haritalandırılması için keşif saldırıları kullanır. Keşif saldırıları erişim saldırılarından veya DoS saldırılarından önce gelir.

Kötü niyetli tehdit aktörleri tarafından keşif saldırıları yapmak için kullanılan bazı teknikler tabloda açıklanmıştır.

Teknik	Açıklama
Hedef hakkında bilgi toplama	Tehdit oyuncusu, bir hedef hakkında bilgi arıyor. Google araması, kuruluşların web sitesi, whois ve daha fazlası dahil olmak üzere çeşitli araçlar kullanılabilir.
Hedef ağın ping taramasını başlatma	Bilgi sorgusu genellikle hedefin ağ adresini gösterir. Tehdit aktörü artık hangi IP adreslerinin aktif olduğunu belirlemek için bir ping taraması başlatılabilir.
Etkin IP adreslerinin bağlantı noktası taramasını başlatma	Hangi bağlantı noktalarının veya hizmetlerin kullanılabilir olduğunu belirlemek için kullanılır. Bağlantı noktası tarayıcılarına örnek olarak Nmap, SuperScan, Angry IP Scanner ve NetScanTools verilebilir.
Güvenlik açığı tarayıcılarını çalıştırma	Bu, bilgisayarda çalışan uygulama ve işletim sisteminin türünü ve sürümünü belirlemek için tanımlanan bağlantı noktalarını sorgulamaktır. Araç örnekleri Nipper, Core Impact, Nessus, SAINT ve Open VAS'dir.
İstismar araçlarını çalıştırma	Tehdit oyuncusu şimdi sömürülebilecek savunmasız hizmetleri keşfetmeye çalışıyor. Metasploit, Core Impact, Sqlmap, Social Engineer Toolkit ve Netsparker gibi çeşitli güvenlik açığından yararlanma araçları bulunmaktadır.

Eriřim Saldırıları

- Eriřim saldırıları, kimlik doęrulama hizmetleri, FTP hizmetleri ve web hizmetlerindeki bilinen güvenlik açıklarından yararlanır. Bu tür saldırıların amacı, web hesaplarına, gizli veri tabanlarına ve dięer hassas bilgilere girmektir.
- Tehdit aktörleri, veri almak, erişim elde etmek veya erişim ayrıcalıklarını yönetici durumuna yükseltmek için ağ cihazlarındaki ve bilgisayarlardaki erişim saldırılarını kullanır.
- Parola Saldırıları: Parola saldırısına, tehdit aktörü çeşitli yöntemler kullanarak kritik sistem parolalarını bulmaya çalışır. Parola saldırıları çok yaygındır ve çeşitli parola kırma araçları kullanılarak başlatılabilir.
- Kimlik Sahtekarlığı Saldırıları: Kimlik sahtekarlığı saldırılarına, tehdit aktörü aygıtı verileri tahrif ederek başka bir aygıt gibi görünmeye çalışır. Yaygın kimlik sahtekarlığı saldırıları arasında IP kimlik sahtekarlığı, MAC sahtekarlığı ve DHCP sahtekarlığı bulunur. Bu kimlik sahtekarlığı saldırıları ileride daha ayrıntılı olarak ele alınacaktır.
- Dięer erişim saldırıları řunları içerir:
 - Güven istismarları
 - Bağlantı noktası yönlendirmeleri
 - Ortadaki adam saldırıları
 - Arabellek taşması saldırıları

Sosyal Mühendislik Saldırıları

- Sosyal mühendislik, bireyleri eylemleri gerçekleştirmeye veya gizli bilgileri ifşa etmeye yönlendirmeye çalışan bir erişim saldırısıdır. Bazı sosyal mühendislik teknikleri bizzat yapılırken, dięerleri telefonu veya interneti kullanabilir.
- Sosyal mühendisler genellikle insanların yardımcı olma istekliliğine güvenir. Ayrıca insanların zayıf yönlerini de avlarlar. (Aldatma Sanatı, Kevin Mitnick)

Sosyal Mühendislik Saldırıları	Açıklama
Pretexting (Bahane Uydurmak)	Bir tehdit aktörü, alıcının kimliğini doęrulamak için kişisel veya finansal verilere ihtiyaç duyuyormuş gibi yapar.
Phishing (Oltalama)	Tehdit aktörü, alıcıyı cihazlarına kötü amaçlı yazılım yüklemesi için kandırmak veya kişisel veya finansal bilgileri paylaşmak için meşru, güvenilir bir kaynaktan olduęu düşünölen sahte e-postalar gönderir.
Spear Phishing (Mızrak Avı)	Bir tehdit aktörü, belirli bir kişi veya kuruluş için özel olarak hazırlanmış, hedeflenen bir kimlik avı saldırısı oluşturur.
Spam (İstenmeyen E-posta)	İstenmeyen posta olarak da bilinir, bu genellikle zararlı bağlantılar, kötü amaçlı yazılım veya aldatıcı içerikler içeren istenmeyen bir e-postadır.

Something for Something (Bir şey için bir şey)	Bazen “Quid pro quo – her şey karşılıklı” olarak da adlandırılır. Bu bir tehdit aktörünün hediye gibi bir şey karşılığında bir kişiden kişisel bilgi talep etmesidir.
Baiting (Yemleme)	Tehdit oyuncusu, kötü amaçlı yazılım bulaşmış bir flash sürücüyü herkese açık bir konumda bırakır. Bir kurban sürücüyü bulur ve istemeden kötü amaçlı yazılım yükleyerek şüphesiz bir şekilde dizüstü bilgisayarlarına yerleştirir.
Impersonation (Başkasının kimliğine bürünme)	Bu tür bir saldırı, bir tehdit aktörünün bir kurbanın güvenini kazanmak için olmadıkları biri gibi davrandığı saldırıdır.
Tailgating (Arkadan Takip)	Burada bir tehdit aktörü, yetkili bir kişiyi güvenli bir bölgeye erişmek için hızlı bir şekilde peşinden takip eder.
Shoulder Surfing (Omuzdan Bakma)	Burada bir tehdit aktörü, parolalarını veya diğer bilgilerini çalmak için göze çarpan bir şekilde birinin omzunun üzerinden bakar.
Dumpster Diving (Çöp Dalışı)	Burada bir tehdit oyuncusu gizli belgeleri bulmak için çöp kutularını karıştırır.

- Social Engineering Toolkit – Sosyal Mühendislik Araç Seti (SET), beyaz şapkalı korsanların ve diğer ağ güvenliği profesyonellerinin kendi ağlarını test etmek için sosyal mühendislik saldırıları oluşturmalarına yardımcı olmak için tasarlanmıştır.
- İşletmeler, kullanıcılarını sosyal mühendisliğin riskleri konusunda eğitmeli ve kimliklerini telefonla, e-posta veya şahsen doğrulamak için stratejiler geliştirmelidir.

DoS ve DDoS Saldırıları

- Denial of Service (Hizmet Reddi - DoS) saldırısı, kullanıcılara, cihazlara veya uygulamalara bir tür ağ hizmetlerinde kesinti oluşturur. İki ana tip DoS saldırısı vardır:
- Ezici Trafik Miktarı – Tehdit Aktörü, ağın, ana bilgisayarın veya uygulamanın işleyemeyeceği kadar büyük miktarda veri gönderir. Bu, iletim ve yanıt sürelerinin yavaşlamasına neden olur. Ayrıca bir cihazı veya hizmeti de bozabilir.
- Kötü Amaçlı Biçimlendirilmiş Paketler – Tehdit aktörü kötü niyetli olarak biçimlendirilmiş bir paketi bir bilgisayara veya uygulamaya gönderir ve alıcı bunu işleyemez. Bu, alıcı cihazın çok yavaş çalışmasına veya çökmesine neden olur.
- DoS saldırıları büyük bir risktir çünkü iletişimi keser ve önemli ölçüde zaman ve para kaybına neden olurlar. Bu saldırıların vasıfsız bir tehdit oyuncusu tarafından bile yürütülmesi nispeten kolaydır.
- Distributed DoS Attack – Dağıtılmış DoS Saldırısı (DDoS), DoS saldırısına benzer, ancak birden çok koordineli kaynaktan kaynaklanır.

IP Güvenlik Açıkları ve Tehditleri

IPv4 ve IPv6

- IP, bir pakette bulunan kaynak IP adreslerinin gerçekten bu kaynaktan gelip gelmediğini doğrulamaz. Bu nedenle tehdit aktörleri, sahte bir kaynak ve IP adresi kullanarak paket gönderebilir. Güvenlik analistleri hem IPv4 hem de IPv6 başlıklarındaki farklı alanları anlamalıdır.
- IP ile ilgili daha yaygın saldırıların bazıları tabloda gösterilmektedir.

IP Attack Techniques	Description
ICMP Attacks (ICMP Saldırıları)	Tehdit aktörleri, korunan bir ağdaki alt ağları ve ana bilgisayarları bulmak, DoS saldırıları oluşturmak ve bilgisayar yönlendirme tablolarını değiştirmek için İnternet Denetim İletisi Protokolü (ICMP) yankı paketlerini (ping) kullanır.
Amplification and Reflection Attacks (Yükseltme ve Yansıtma Saldırıları)	Tehdit aktörleri, meşru kullanıcıların DoS ve DDoS saldırılarını kullanarak bilgi veya hizmetlere erişmesini engellemeye çalışır.
Address Spoofing Attacks (Adres Sahtekarlığı Saldırıları)	Tehdit aktörleri, kör kimlik sahtekarlığı veya kör olmayan kimlik sahtekarlığı gerçekleştirmek için kaynak IP adresini bir IP paketinde taklit eder.
Man-in-the-Middle Attack (Ortadaki Adam Saldırısı)	Tehdit aktörleri, iletişimi şeffaf bir şekilde izlemek, yakalamak ve kontrol etmek için kendilerini kaynak ve hedef arasına konumlandırır. Yakalanan paketleri inceleyerek dinleyebilir veya paketleri değiştirip orijinal varış yerlerine iletebilirler.
Session Hijacking (Oturum Ele Geçirme)	Tehdit aktörleri fiziksel ağa erişir ve ardından bir oturumu ele geçirmek için bir MITM saldırısı kullanır.

ICMP Saldırıları

- Tehdit aktörleri keşif ve tarama saldırıları için ICMP kullanır. Bir ağ topolojisini haritalamak, hangi bilgisayarların etkin (erişilebilir) olduğunu keşfetmek, ana bilgisayar işletim sistemini (OS parmak izi) tanımlamak ve bir güvenlik duvarının durumunu belirlemek için bilgi toplama saldırıları başlatabilirler. Tehdit aktörleri ayrıca DoS saldırıları için ICMP kullanır.
- Not: IPv4 için ICMP (ICMPv4) ve IPv6 için ICMP (ICMPv6) benzer saldırı türlerine karşı hassastır.
- Ağlarda, ICMP'nin internetten araştırılmasını önlemek için ağların ağ kenarında sıkı ICMP erişim kontrol listesi (ACL) filtrelemesi olmalıdır. Büyük

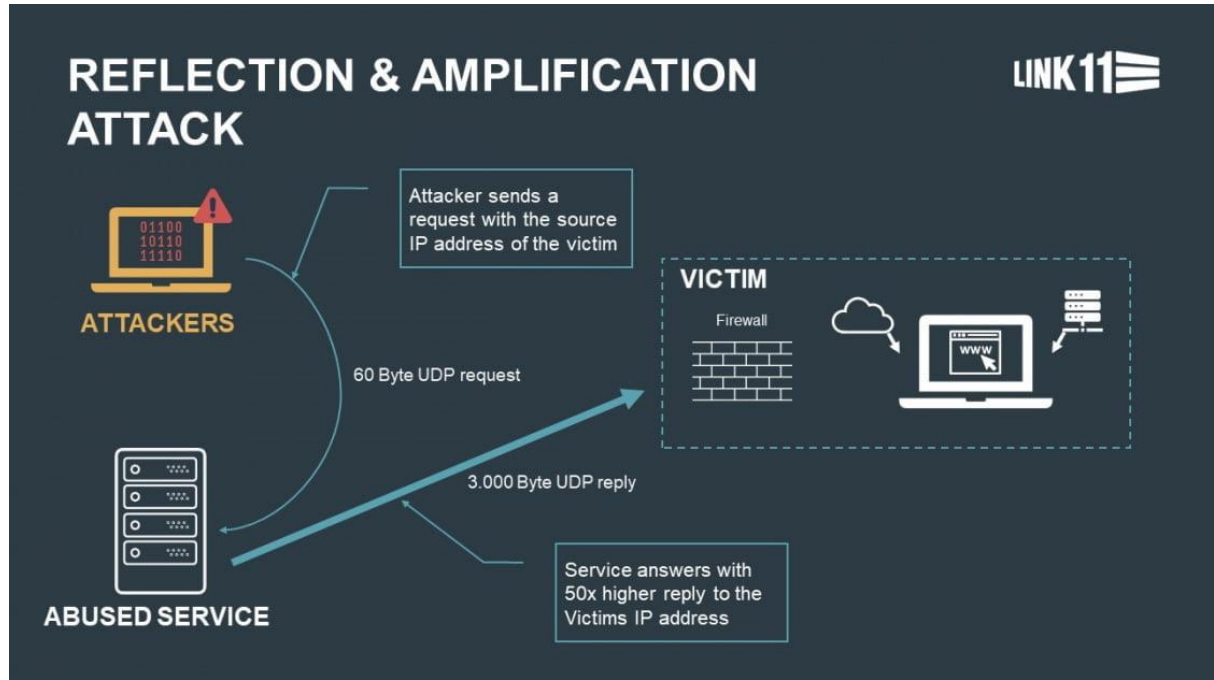
ağlarda, güvenlik duvarları ve saldırı tespit sistemleri (IDS) gibi güvenlik aygıtları bu tür saldırıları algılar ve güvenlik analistleri için uyarılar oluşturur.

Tehdit aktörlerinin kullandığı yaygın ICMP mesajları tabloda listelenmiştir.

Hackerlar tarafından kullanılan ICMP Mesajları	Açıklama
ICMP echo request and echo reply (ICMP yankı isteği ve yankı yanıtı)	Bu, ana makine doğrulaması ve DoS saldırıları gerçekleştirmek için kullanılır.
ICMP unreachable (ICMP hedefe ulaşamaz)	Bu, ağ keşif ve tarama saldırıları gerçekleştirmek için kullanılır.
ICMP mask reply (ICMP maskesi yanıtı)	Bu, dahili bir IP ağını eşlemek için kullanılır.
ICMP redirects (ICMP yönlendirmeleri)	Bu, hedef ana makineyi güvenliği ihlal edilmiş bir cihaz üzerinden tüm trafiği göndermeye çekmek ve bir MITM saldırısı oluşturmak için kullanılır.
ICMP router discovery (ICMP Router Keşif)	Bu, bir hedef ana bilgisayarın yönlendirme tablosuna sahte yol girişlerini enjekte etmek için kullanılır.

Yükseltme ve Yansıtma Saldırıları

- Tehdit aktörleri genellikle DoS saldırıları oluşturmak için amplifikasyon ve yansıtma tekniklerini kullanır. Şekildeki örnek, bir hedef ağı bunaltmak için bir Smurf saldırısının kullanıldığını göstermektedir. (Banka DDoS)
- Not: DNS tabanlı yansıtma ve amplifikasyon saldırıları ve Ağ Zaman Protokolü (NTP) amplifikasyon saldırıları gibi daha yeni amplifikasyon ve yansıtma saldırıları kullanılmaktadır.
- Tehdit aktörleri ayrıca bir hedef ana bilgisayarını çökertmek veya bir ağın kaynaklarını tüketmek için kaynak tüketme saldırılarını kullanır.



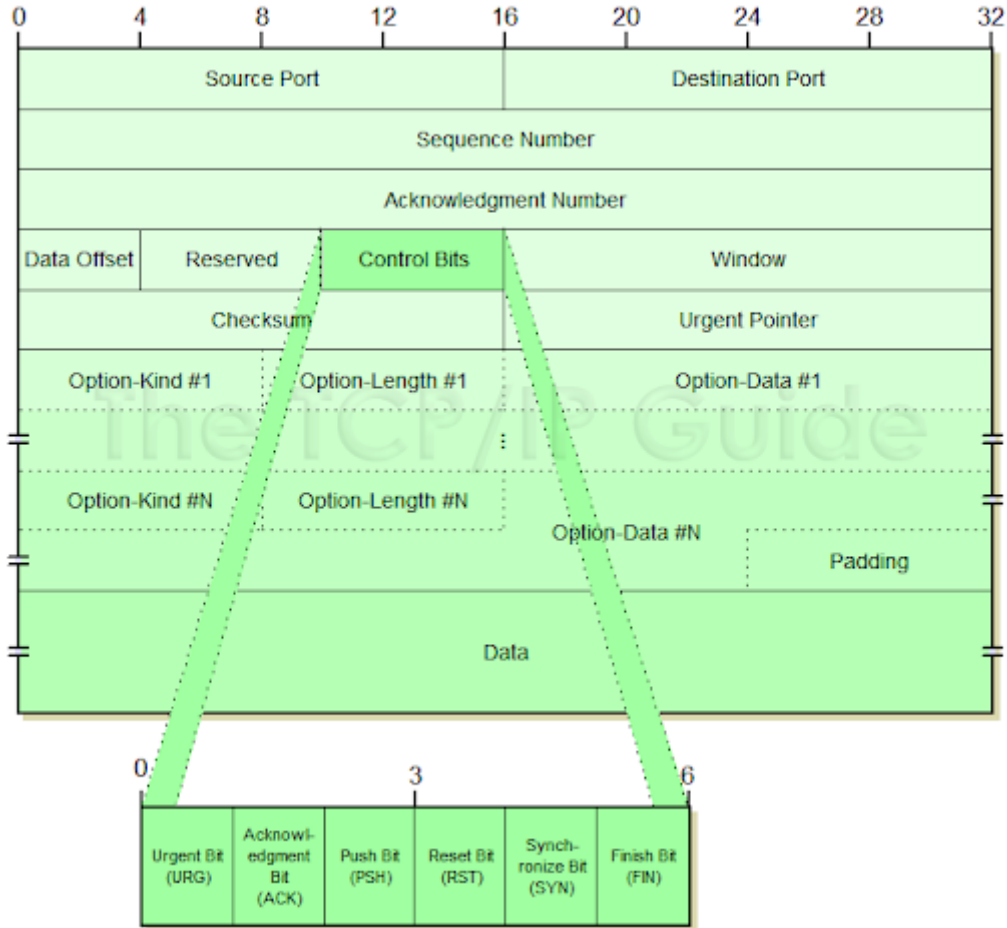
Adres Sahtekarlığı Saldırıları

- IP adresi kimlik sahtekarlığı saldırıları, bir tehdit oyuncusu gönderenin kimliğini gizlemek veya başka bir meşru kullanıcı olarak göstermek için yanlış kaynak IP adresi bilgilerine sahip paketler oluşturduğundan gerçekleşir. Kimlik sahtekarlığı genellikle bir Smurf saldırısı gibi başka bir saldırıya dahil edilir.
- Kimlik sahtekarlığı saldırıları iki türdür: kör olan veya kör olmayan
- Kör olmayan kimlik sahtekarlığı – Tehdit aktörü, ana bilgisayar ile hedef arasında gönderilen trafiği görebilir. Kör olmayan kimlik sahtekarlığı, bir güvenlik duvarının durumunu ve sıra numarası tahminini belirler. Yetkili bir oturumu da ele geçirebilir.
- Kör kimlik sahtekarlığı – Tehdit aktörü, ana bilgisayar ile hedef arasında gönderilen trafiği göremez. DoS saldırılarında kör kimlik sahtekarlığı kullanılır.
- Tehdit aktörlerinin dahili ağı erişimi olduğunda MAC adresi kimlik sahtekarlığı saldırıları kullanılır. Tehdit aktörleri, ana bilgisayarlarının MAC adreslerini, hedef ana bilgisayarın bilinen başka bir MAC adresiyle eşleştirecek şekilde değiştirir.

TCP ve UDP Güvenlik Açıkları

TCP Segment Header (TCP Segment Başlığı)

- TCP bölüm bilgileri IP üstbilgisinden hemen sonra görünür. TCP segmentinin alanları ve kontrol bitleri alanının bayrakları şekilde gösterilmiştir.
- TCP segmentinin altı kontrol biti aşağıdadır:
- **URG** – Urgent pointer field significant (Acil İşrateçi Alanı)
- **ACK** – Acknowledgement field significant (Teşekkür/Kabul alanı)
- **PSH** – Push function (İtme işlevi)
- **RST** – Reset the Connection (Bağlantıyı sıfırla)
- **SYN** – Synchronize sequence numbers (Sıra numaralarını senkronize etme)
- **FIN** – No more data from sender (Gönderenden başka veri yok)



TCP Servisleri

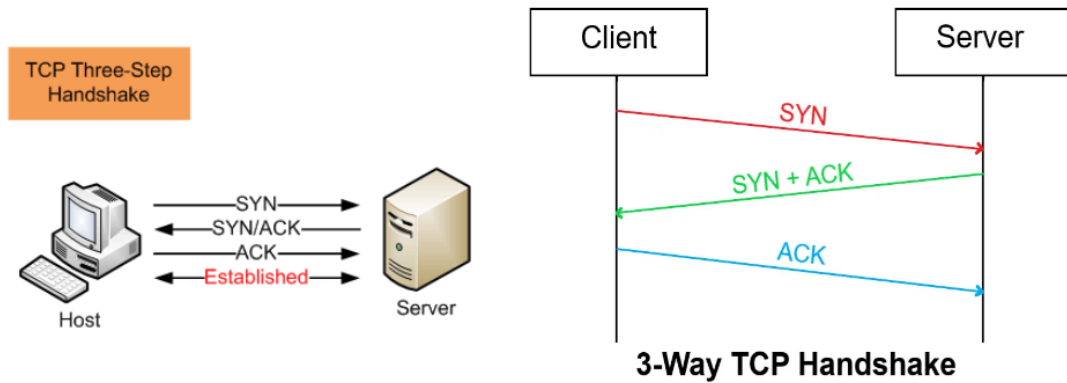
TCP şu hizmetleri sağlar:

- **Reliable Delivery (Güvenilir Teslimat):** TCP, teslimatı garanti etmek için onayları içerir. Zamanında onay alınmazsa, gönderen verileri yeniden iletir. Alınan verilerin onaylanmasını istemek önemli gecikmelere neden olabilir. TCP güvenilirliğini kullanan uygulama katmanı protokollerine örnek olarak http, SSL/TLS, FTP, DNS bölge aktarımları ve diğerleri verilebilir.
- **Flow Control (Akış Kontrolü):** TCP, bu sorunu gidermek için akış kontrolü uygular. Bir kerede bir segmenti kabul etmek yerine, tek bir alındı birimi ile birden fazla segment kabul edilebilir.
- **Stateful Communication (Durum Bilgisi Olan İletişim):** İki taraf arasında TCP durum bilgisi olan iletişim, TCP'nin üç yönlü el sıkışması sırasında gerçekleşir.

Üç adımda bir TCP bağlantısı kurulur:

- 1) Başlatılan istemci, sunucuyla bir istemciden sunucuya iletişim oturumu ister.
- 2) Sunucu, istemciden sunucuya iletişim oturumunu onaylar ve sunucudan istemciye iletişim oturumu ister.
- 3) Başlatılan istemci, sunucudan istemciye iletişim oturumunu onaylar.

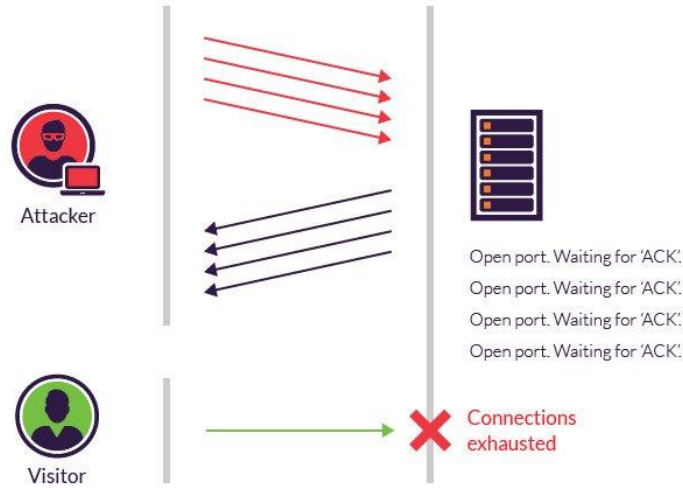
3 Way TCP handshake to establish a TCP Connection



TCP Saldırıları

TCP SYN Flood Attack (TCP SYN Sel Saldırısı)

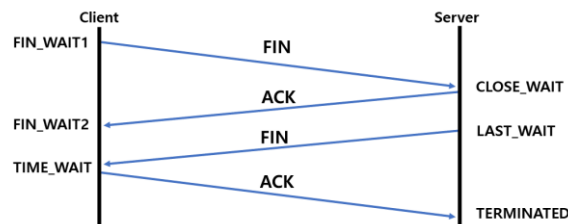
1. Tehdit aktörü bir web sunucusuna birden fazla SYN isteği gönderir.
2. Web sunucusu, her SYN isteği için SYN-ACK'larla yanıt verir ve üç yollu el sıkışmasını tamamlamayı bekler. Tehdit aktörü SYN-ACK'lara yanıt vermez.
3. Geçerli bir kullanıcı, web sunucusunda yarı açık çok fazla TCP bağlantısı bulunduğu için web sunucusuna erişemez.



TCP oturumunu sonlandırmak için aşağıdaki dört yönlü değişim işlemi kullanılır:

1. İstemcinin akışta gönderecek başka veri yoksa, FIN bayrağı ayarlanmış bir segment gönderir.
2. Sunucu, oturumu istemciden sunucuya sonlandırmak için FIN'nin alındığını onaylamak için bir ACK gönderir.
3. Sunucu, sunucudan istemciye oturumu sonlandırmak için istemciye bir FIN gönderir.
4. İstemci bir ACK ile yanıt verir ve sunucudan FIN'yi onaylar.

Bir tehdit aktörü TCP sıfırlama saldırısı yapabilir ve bir TCP RST içeren sahte bir paket gönderebilir.



TCP oturumu ele geçirme başka bir TCP güvenlik açığıdır. Yürütülmesi zor olsa da, bir tehdit aktörü, hedefle iletişim kurarken zaten kimliği doğrulanmış bir ana bilgisayarı devralır. Tehdit aktörü bir ana bilgisayarın IP adresini aldatmalı, sonraki sıra numarasını tahmin etmeli ve diğer ana bilgisayar bir ACK göndermelidir. Başarılı olursa, tehdit aktörü hedef cihazdan veri gönderebilir, ancak alamaz.

UDP Segment Header and Operation (UDP Segment Başlığı ve İşlemi)

- UDP (User Datagram Protocol) yaygın olarak DNS, TFTP, NFS ve SNMP tarafından kullanılır. Medya akışı veya VoIP gibi gerçek zamanlı uygulamalarla da kullanılır. UDP bağlantısız bir taşıma katmanı protokolüdür. TCP'ye göre çok daha düşük ek yüke sahiptir, çünkü bağlantı odaklı değildir ve güvenilirlik sağlayan gelişmiş yeniden iletim, sıralama ve akış kontrol mekanizmaları sunmaz.
- Bu güvenilirlik işlevleri, taşıma katmanı protokolü tarafından sağlanmaz ve gerekirse başka bir yerde uygulanmalıdır.
- UDP'nin düşük ek yükü, basit talep ve yanıt işlemleri yapan protokoller için çok arzu edilir kılımdır.

TCP Segment Header Format								
Bit #	0	7	8	15	16	23	24	31
0	Source Port				Destination Port			
32	Sequence Number							
64	Acknowledgment Number							
96	Data Offset	Res	Flags			Window Size		
128	Header and Data Checksum				Urgent Pointer			
160...	Options							

UDP Datagram Header Format									
Bit #	0	7	8	15	16	23	24	31	
0	Source Port				Destination Port				
32	Length				Header and Data Checksum				

UDP Saldırıları

- UDP herhangi bir şifreleme ile korunmaz. UDP'ye şifreleme ekleyebilirsiniz, ancak varsayılan olarak kullanılmaz. Şifrelemenin olmaması, herkesin trafiği görebileceği, değiştirebileceği ve hedefine gönderebileceği anlamına gelir.
- UDP Flood Attacks (UDP Sel Saldırıları): Tehdit aktörü UDP Unicorn veya Low Orbit Ion Cannon gibi bir araç kullanır. Bu araçlar, genellikle sahte bir ana bilgisayardan alt ağdaki bir sunucuya bir UDP paketi seli gönderir. Program, kapalı portları bulmaya çalışan bilinen tüm portları tarayacaktır. Bu, sunucunun ICMP bağlantı noktasına erişilemiyor olmasıyla yanıt vermesine neden olur. Sunucuda çok sayıda kapalı bağlantı noktası bulunduğundan, bu, segmentte bant genişliğinin çoğunu kullanan çok fazla trafik oluşturur. Sonuç bir DoS saldırısına çok benzer

IP Servisleri

ARP Vulnerabilities (ARP Güvenlik Açıkları)

- Ana bilgisayarlar, belirli bir IP adresine sahip bir ana bilgisayarın MAC adresini belirlemek için segmentteki diğer ana bilgisayarlara ARP isteği yayınlar. ARP isteğinde eşleşen IP adresine sahip ana bilgisayar bir ARP yanıtı gönderir.
- Herhangi bir istemci, “gratuitous – nedensiz, kendi isteğiyle” ARP olarak adlandırılan, istenmeyen bir ARP Yanıtı gönderebilir. Bir ana bilgisayar, gratuitous bir ARP gönderdiğinde, alt ağdaki diğer ana bilgisayarlar, arp tablolarında gratuitous ARP’de bulunan MAC adresini ve IP adresini depolar.
- ARP’nin bu özelliği ayrıca herhangi bir ana bilgisayarın herhangi bir IP veya MAC’ın sahip olduğunu iddia edebileceği anlamına gelir. Bir tehdit aktörü, yerel ağdaki ARP önbelleklerini zehirleyerek trafiği yönlendirmek için bir MITM saldırısı oluşturabilir.

ARP Cache Poisoning (ARP Önbellek Zehirlenmesi)

ARP önbellek zehirlenmesi, çeşitli ortadaki adam saldırılarını başlatmak için kullanılabilir.

- PC-A, varsayılan ağ geçidinin (R1) MAC adresini gerektirir; bu nedenle 192.168.10.1 MAC adresi için bir ARP Talebi gönderir.
- R1, ARP önbelleğini PC-A’nın IP ve MAC adresleriyle günceller. R1, PC-A’ya bir ARP Yanıtı gönderir ve daha sonra ARP önbelleğini R1’in IP ve MAC adresleriyle güncelleştirir.
- Tehdit aktörü belirtilen hedef IP adresleri için kendi MAC adresini kullanarak iki sahte ARP Yanıtı gönderir. PC-A, ARP önbelleğini şimdi tehdit oyuncusunun ana bilgisayar MAC adresini işaret eden varsayılan ağ geçidi ile günceller. R1 ayrıca ARP önbelleğini tehdit oyuncusunun MAC adresini gösteren PC-A’nın IP adresiyle günceller.

ARP zehirlenmesi saldırısı pasif veya aktif olabilir. Pasif ARP zehirlenmesi, tehdit aktörlerinin gizli bilgileri çaldığı yerdir. Aktif ARP zehirlenmesi, tehdit aktörlerinin transit verileri değiştirdiği veya kötü amaçlı verileri enjekte ettiği yerdir.

DNS Saldırıları

- Domain Name Service – Etki Alan Adı Hizmeti (DNS) Protokolü, www.cisco.com gibi kaynak adlarıyla IPv4 veya IPv6 adresi gibi gerekli sayısal ağ adresiyle eşleşen otomatik bir hizmet tanımlar. Sorguların, yanıtların ve verilerin biçimini içerir ve DNS yanıtı türünü tanımlamak için kaynak kayıtları (RR) kullanır.
- DNS'nin güvenliğini sağlama genellikle göz ardı edilir. Bununla birlikte, bir ağın çalışması için çok önemlidir ve buna göre emniyet altına alınmalıdır.
- DNS saldırıları aşağıdakileri içerir:
 - DNS açık çözümleyici saldırıları
 - DNS gizi saldırıları
 - DNS etki alanı gölgeleme saldırıları
 - DNS tünel saldırıları

DNS Açık Çözümleyici Saldırıları: DNS açık çözümleyici, yönetim etki alanının dışındaki istemcilerden gelen sorguları yanıtlar. DNS açık çözümleyicileri tabloda açıklanan birden çok kötü amaçlı etkinliğe karşı savunmasızdır.

DNS Çözümleyici Güvenlik Açıkları	Açıklama
DNS önbellek zehirlenmesi saldırıları	Tehdit aktörleri, kullanıcıların yasal sitelerden kötü amaçlı sitelere yönlendirmek için sahte kayıt kaynağı (RR) bilgilerini bir DNS çözümleyicisine gönderir. DNS önbellek zehirlenmesi saldırılarının tümü, DNS çözümleyicisine kötü amaçlı etkinlikler için RR bilgileri sağlayan kötü amaçlı bir ad sunucusu kullanmasını bildirmek için kullanılabilir.
DNS yükseltme ve yansıtma saldırıları	Tehdit aktörleri, saldırı hacmini artırmak ve gerçek bir saldırı kaynağını gizlemek için DNS açık çözümleyicilere DoS ve DDoS saldırıları kullanır. Tehdit aktörleri, hedef ana bilgisayarın IP adresini kullanarak açık çözümleyicilere DNS mesajları gönderir. Bu saldırılar mümkündür, çünkü açık çözümleyici soru soran herkesin sorgularına yanıt verecektir.
DNS kaynak kullanım saldırıları	DNS açık çözümleyicilerinin kaynaklarını tüketen bir DoS saldırısı. Bu DoS saldırısı, DNS açık çözümleyicinin işlemlerini olumsuz etkilemek için mevcut tüm kaynakları tüketir. Bu DoS saldırısının etkisi, DNS açık çözümleyicinin yeniden başlatılmasını veya hizmetlerin durdurulmasını gerektirebilir.

DNS Gizli Saldırıları: Tehdit aktörleri kimliklerini gizlemek için saldırılarını gerçekleştirmek için tabloda açıklanan DNS gizli tekniklerini de kullanırlar.

DNS Gizli Teknikleri	Açıklama
Fast Flux (Hızlı Akış)	Tehdit aktörleri, kimlik avı ve kötü amaçlı yazılım dağıtım sitelerini, hızla değişen güvenliği ihlal edilmiş DNS ana bilgisayarlarının ağının arkasına gizlemek için bu tekniği kullanır. DNS IP adresleri dakikalar içinde sürekli olarak değiştirilir. Bot ağları, kötü amaçlı sunucuların tespit edilmesini etkili bir şekilde gizlemek için genellikle Fast Flux tekniklerini kullanır.
Double IP Flux (Çift IP Akışı)	Tehdit aktörleri, ana bilgisayar adını hızlı bir şekilde IP adresi eşlemelerine değiştirmek ve ayrıca yetkili ad sunucusunu değiştirmek için bu tekniği kullanır. Bu, saldırının kaynağını tanımlama zorluğunu artırır.
Domain Generation Algorithms (Alan Adı Üretimi Algoritmaları)	Tehdit aktörleri, bu tekniği kötü amaçlı yazılımlarda, daha sonra komut ve kontrol (C&C) sunucularına buluşma noktaları olarak kullanılabilecek rastgele etki alanı adları oluşturmak için kullanır.

DNS Domain Shadowing - Etki Alanı Gölgeleme Saldırıları: Etki alanı gölgelemesi, saldırılar sırasında kullanılacak birden çok alt etki alanını sessize oluşturmak için etki alanı hesabı kimlik bilgilerini toplayan tehdit aktörünü içerir. Bu alt alanlar genellikle üst etki alanının gerçek sahibini uyardan kötü amaçlı sunuculara işaret eder.

DNS Tünelleme

- DNS Tüneli kullanan tehdit aktörleri, DNS dışı trafiği DNS trafiğine yerleştirir. Bu yöntem, bir tehdit aktörü korumalı bir ağ içindeki botlarla iletişim kurmak veya kuruluştan veri sızdırmak istediğinde genellikle güvenlik çözümlerini atlatır. DNS tüneli, bir botnet'e gönderilen CnC komutları şu şekilde çalışır:
 - Komut verileri birden fazla kodlanmış parçaya bölünür.
 - Her yığın, DNS sorgusunun daha alt düzey bir etki alanı adı etiketine yerleştirilir.
 - Sorgu için yerel veya ağa bağlı DNS'den yanıt alınmadığından, istek İSS'nin özyinelemeli DNS sunucularına gönderilir.
 - Özyinelemeli DNS hizmeti, sorguyu tehdit oyuncusunun yetkili ad sunucusuna iletir.
 - Parçaları içeren tüm sorgular gönderilinceye kadar işlem tekrarlanır.
 - Tehdit oyuncusunun yetkili ad sunucu etkilenen cihazlardan DNS sorguları aldığı anda, kapsüllenmiş, kodlanmış CnC komutlarını içeren her DNS sorgusu için yanıtlar gönderir.
 - Güvenliği ihlal edilen ana bilgisayardaki kötü amaçlı yazılım parçaları birleştirir ve DNS kaydında gizlenmiş komutları yürütür.

- DNS tünellemesini durdurmak için ağ yöneticisinin DNS trafiğini denetleyen bir filtre kullanması gerekir. Ortalamadan uzun veya şüpheli alan adına sahip DNS sorgularına dikkat edin.

DHCP

- DHCP sunucuları, istemcilere dinamik olarak IP yapılandırma bilgileri sağlar.
- İstemci bir DHCP keşif mesajı yayınlamaktadır. DHCP, istemcinin kullanabileceği adresleme bilgilerini içeren tek noktaya yayın teklifiyle yanıt verir. İstemci, teklifi kabul ettiğini sunucuya bildirmek için bir DHCP isteği yayınlar. Sunucu, isteği kabul eden bir tek noktaya yayın onayı ile yanıt verir.

DHCP Saldırıları

- Bir DHCP Spoofing – Kimlik Sahtekarlığı Saldırısı, sahte bir DHCP sunucusu ağa bağlandığında ve yasal istemcilere yanlış IP yapılandırma parametrelerini sağladığında gerçekleşir. Sahte bir sunucu çeşitli yanıltıcı bilgiler sağlayabilir:
 - Yanlış varsayılan ağ geçidi – Tehdit aktörü, bir MITM saldırısı oluşturmak için geçersiz bir ağ geçidi veya ana bilgisayarının IP adresini sağlar. Davetsiz misafir ağ üzerinden veri akışına müdahale ettiği için bu tamamen tespit edilemez.
 - Yanlış DNS sunucusu – Tehdit aktörü kullanıcıyı kötü amaçlı bir web sitesine yönlendiren yanlış bir DNS sunucusu adresi sağlar.
 - Yanlış IP adresi – Tehdit aktörü geçersiz bir IP adresi, geçersiz varsayılan ağ geçidi IP adresi veya her ikisini birden sağlar. Tehdit oyuncusu daha sonra DHCP istemcisine bir DoS saldırısı oluşturur.

Bir tehdit aktörünün, sahte bir DHCP sunucusunu hedef istemcilere aynı alt ağdaki bir anahtar bağlantı noktasına başlarıyla bağladığını varsayın. Sahte sunucunun amacı, istemcilere yanlış IP yapılandırma bilgileri sağlamaktır.

1. İstemci, bir DHCP sunucusundan yanıt arayan bir DHCP Keşfi isteği yayınlar. Her iki sunucu da mesajı alır.
2. Meşru ve aldatıcı DHCP sunucularının her biri geçerli bir IP yapılandırma parametreleriyle yanıt verir. Müşteri, alınan ilk teklife yanıt verir.
3. İstemci önceden sahte teklifi aldı. Sahte sunucudan parametreleri kabul eden bir DHCP isteği yayınlar. Meşru ve dolandırıcı sunucunun her biri isteği alır.
4. Yalnızca sahte sunucu, isteğini kabul etmesi için istemciye bir yanıt gönderir. Meşru sunucu, istek zaten onaylandığından istemci ile iletişim kurmayı durdurur.

En İyi Ağ Güvenliği Uygulamaları

Confidentiality, Availability, and Integrity (Gizlilik, Kullanılabilirlik ve Güvenilirlik)

- Ağ güvenliği, bilgi ve bilgi sistemlerini yetkisiz erişim, kullanım, ifşa, aksama, değişiklik veya yıkımdan korumaktan oluşur.
- Çoğu kuruluş CAI bilgi güvenliği üçlemesini takip eder:
- Gizlilik: Hassas bilgilere yalnızca yetkili kişiler, kuruluşlar veya işlemler erişebilir. Verileri şifrelemek ve şifresini çözmek için AES gibi şifreleme algoritmalarının kullanılmasını gerektirebilir.
- Kullanılabilirlik: Yetkili kullanıcıların önemli kaynaklara ve verilere kesintisiz erişimi olmalıdır. Yedekli servislerin, ağ geçitlerinin ve bağlantıların uygulanmasını gerektirir.
- Güvenilirlik: Verileri yetkisiz değişikliklerden korumayı ifade eder. SHA gibi kriptografik karma algoritmalarının kullanılmasını gerektirir.

Derinlemesine Savunma Yaklaşımı

- Hem genel hem de özel ağlar arasında güvenli iletişim sağlamak için yönlendiriciler, anahtarlar, sunucular ve ana bilgisayarlar da dahil olmak üzere aygıtları güvenli hale getirmelisiniz. Çoğu kuruluş güvenliğe derinlemesine bir savunma yaklaşımı uygular. Birlikte çalışan ağ cihazları ve hizmetlerinin bir kombinasyonunu gerektirir.
- Çeşitli güvenlik aygıtları ve hizmetleri uygulanmaktadır.
 - **VPN**
 - **ASA Firewall**
 - **IPS**
 - **ESA/WSA**
 - **AAA Server**
- Yönlendirici ve anahtarlar dahil tüm ağ aygıtları sıkılaştırılmalıdır. Ayrıca çeşitli bağlantılar arasında dolaşırken verilerin güvenliğini sağlamalısınız.

Firewall

Güvenlik duvarı, ağlar arasında erişim denetimi ilkesini uygulayan bir sistem veya sistem grubudur. İç ağ ile dış ağ arasındaki gelen-giden trafiği kontrol eden, izin verilenleri geçirip, tehlikeli veya istenmeyen trafiği engelleyen güvenlik sistemidir.

- Trafiği kurallara göre filtreler
- Zararlı bağlantıları engeller
- Port ve IP tabanlı kontrol yapar
- DMS, LAN gibi ağ bölümlerini korur

IPS

- Hızlı hareket eden ve gelişen saldırılara karşı savunmak için, ağın giriş ve çıkış noktalarına entegre edilmiş uygun maliyetli algılama ve önleme sistemlerine ihtiyacınız olabilir.
- IDS ve IPS teknolojileri birçok özelliği paylaşır. IDS ve IPS teknolojilerinin her ikisi de sensör olarak dağıtılır. Bir IDS veya IPS sensörü birkaç farklı cihaz şeklinde olabilir.
 - Cisco IOS IPS yazılımı ile yapılandırılmış bir yönlendirici
 - Özel IDS veya IPS hizmetleri sağlamak için özel olarak tasarlanmış bir cihaz
 - Uyarlanabilir bir güvenlik cihazına (ASA), anahtara veya yönlendiriciye takılmış bir ağ modülü
 - IDS ve IPS teknolojileri, kötü niyetli etkinlikleri tespit etmek için kullanılan bir dizi kural ola imzalar kullanarak ağ trafiğindeki kalıpları algılar. IDS ve IPS teknolojileri atom imza kalıplarını (tek paket) veya bileşik imza kalıplarını (çoklu paket) algılayabilir.
- IPS'nin reddedilen trafiği nasıl ele aldığına bakalım:
 - Tehdit oyuncusu, hedef dizüstü bilgisayar için hedeflenen bir paket gönderir.
 - IPS trafiği durdurur ve bilinen tehditlere ve yapılandırılmış ilkelere göre değerlendirir.
 - IPS, yönetim konsoluna bir günlük iletisi gönderir.
 - IPS paketi düşürür.

İçerik Güvenlik Cihazları

- Cisco E-posta Güvenlik Uygulaması (ESA – Email Security Appliance), Basit Posta Aktarım Protokolü'nü (SMTP) izlemek için tasarlanmış özel bir cihazdır. Cisco ESA, Cisco Talos'un gerçek zamanlı yayınlarıyla sürekli güncellenir. Bu tehdit istihbarat verileri, her üç ila beş dakikada bir Cisco ESA tarafından alınır.
- Cisco Web Güvenlik Cihazı (WSA – Web Security Appliance), web tabanlı tehditler için bir azaltma teknolojisidir. Cisco WSA, gelişmiş kötü amaçlı yazılım koruması, uygulama görünürlüğü ve kontrolü, kabul edilebilir kullanım politikası kontrolleri ve raporlamayı birleştirir.
- Cisco WSA, kullanıcıların internete nasıl eriştiği üzerinde tam kontrol sağlar. WSA, URL'lerin kara listeye alınması, URL filtreleme, kötü amaçlı yazılım taraması, URL kategorizasyonu, web uygulaması filtrelemesi ve web trafiğinin şifrenmesi ve şifresinin çözülmesi işlemlerini gerçekleştirebilir.

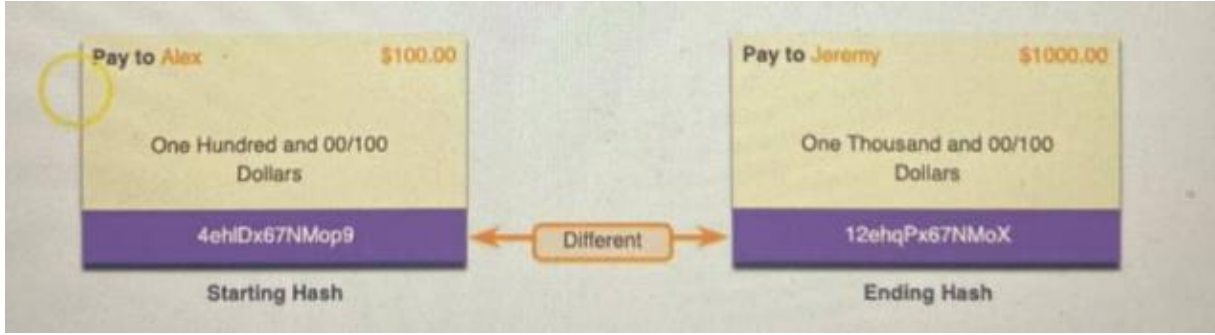
Kriptografi

İletişimlerin Güvenliğini Sağlama

- Kuruluşlar, bağlantılar arasında dolaşırken verilerin güvenliğini sağlamak için destek sağlamalıdır. Bu, iç trafiği içerebilir, ancak kuruluşun dışına seyahat eden verilerin korunması daha da önemlidir.
- Bunlar güvenli iletişimin dört ögesidir:
 - Veri Bütünlüğü: Mesajın değiştirilmediğini garanti eder. Bütünlük, Message Digest sürüm 5 (MD5) veya Secure Hash Algorithm (SHA – Güvenli Karma Algoritması) karma üreten algoritmalar uygulanarak sağlanır.
 - Orijin Kimlik Doğrulaması: Mesajın sahte olmadığını ve bildirdiği kişiden geldiğini garanti eder. Birçok modern ağ, karma mesaj kimlik doğrulama kodu (HMAC) gibi protokollerle kimlik doğrulaması sağlar.
 - Veri Gizliliği: Mesajı yalnızca yetkili kullanıcıların okuyabileceğini garanti eder. Veri gizliliği simetrik ve asimetrik şifreleme algoritmaları kullanılarak uygulanır.
 - Reddedilmeyecek Veriler: Gönderenin gönderilen bir iletinin geçerliliğini reddedemeyeceğini garanti eder. Reddetmeme, yalnızca gönderenin bu iletinin nasıl ele alındığına ilişkin benzersiz özelliklere veya imzasına sahip olmasına dayanır.

Data Integrity (Veri Bütünlüğü)

- Hash işlevleri, bir mesajın bütünlüğünü sağlamak için kullanılır. İletim verilerinin yanlışlıkla veya kasıtlı olarak değiştirilmediğini garanti ederler.
 - Şekilde, gönderen Alex'e 100 dolarlık bir para transferi gönderiyor. Gönderen, iletinin alıcıya giderken değiştirilmediğinden emin olmak istiyor.
- 1) Gönderen cihaz mesajı bir karma algoritmaya girer ve sabit uzunluklu 4ehiDx67NMop9 karmasını hesaplar.
 - 2) Bu karma daha sonra mesaja eklenir ve alıcıya gönderilir. Hem mesaj hem de karma düz metindir.
 - 3) Alıcı cihaz karmayı mesajdan kaldırır ve mesajı aynı karma algoritmaya girer. Hesaplanan karma mesaja ekli olana eşitse, mesaj taşıma sırasında değiştirilmemiştir. Karma değerlere eşit değilse, iletinin bütünlüğüne artık güvenilemez.



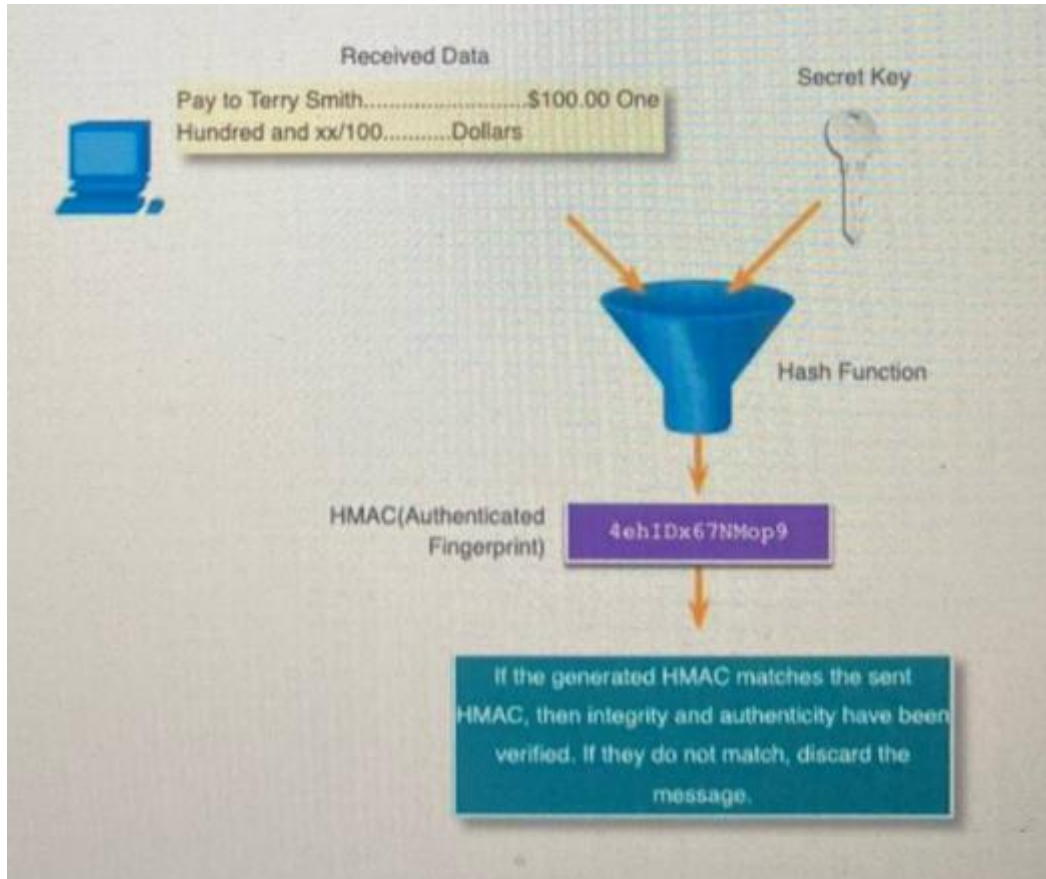
Hash Functions (Karma İşlevleri)

Bilinen iç karma işlevi vardır.

- 1) 128-bit Özet ile MD5: MD5, 128 bit karma mesaj üreten tek yönlü bir fonksiyondur. MD5, yalnızca daha iyi alternatif olmadığında kullanılması gereken eski bir algoritmadır. Bunun yerine SHA-2 kullanın.
 - 2) SHA Karma Algoritması: SHA-1, MD5 karma işlevlerine çok benzer. SHA-1, 160 bitlik karma bir ileti oluşturur ve MD5'ten biraz daha yavaştır. SHA-1 bilinen kusurlara sahiptir ve eski bir algoritmadır. Mümkünse SHA-2 kullanın.
 - 3) SHA-2: SHA-224 (224 bit), SHA-256 (256 bit), SHA-384 (384 bit) ve SHA-512 (512 bit) içerir. SHA-256, SHA-384 ve SHA-512 yeni nesil algoritmalar ve mümkün olduğunda kullanılmalıdır.
- Karma, yanlışlıkla yapılan değişiklikleri tespit etmek için kullanılabilirken, kasıtlı değişikliklere karşı korunmak için kullanılamaz. Bu, doğru sağlama işlevine sahipse, herhangi bir veri için bir karma hesaplayabileceği anlamına gelir.
 - Bu nedenle, karma, ortadaki adam saldırılarına karşı savunmasızdır ve iletilen verilere güvenlik sağlamaz.

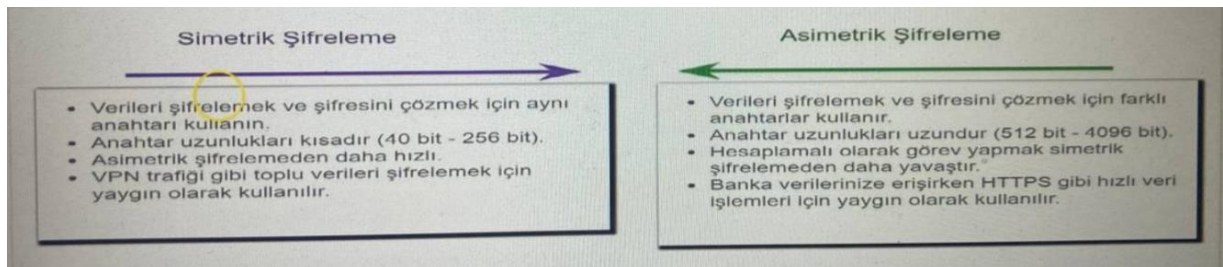
Origin Authentication (Kaynak Kimlik Doğrulaması)

- Bütünlük güvencesine kimlik doğrulama eklemek için, hash message authentication code (anahtarlı karma ileti kimlik doğrulama kodu - HMAC) kullanın.
- Bir HMAC, bir şifreleme karma işlevini gizli bir anahtarla birleştiren herhangi bir şifreleme algoritması kullanılarak hesaplanır.
- Yalnızca bu gizli anahtara erişimi olan taraflar bir HMAC işlevinin özetini hesaplayabilir. Bu, ortadaki adam saldırılarını yener ve veri kaynağının doğrulanmasını sağlar.



Data Confidentiality (Veri Gizliliği)

- Veri gizliliği sağlamak için kullanılan iki şifreleme sınıfı vardır. Bu iki sınıf, anahtarları kullanma biçimlerine göre farklılık gösterir.
- (DES), 3DES ve Advanced Encryption Standard – Gelişmiş Şifreleme Standardı (AES) gibi simetrik şifreleme algoritmaları, iletişim kuran her bir tarafın önceden paylaşılan anahtarı bildiği öncülüne dayanır. Veri gizliliği Rivest, Shamir ve Adleman (RSA) ve ortak anahtar altyapısı (PKI- Public Key Infrastructure) dahil olmak üzere asimetrik algoritmalar kullanılarak da sağlanabilir.
- Şekilde her bir şifreleme algoritması yöntemi arasındaki bazı farklılıklar vurgulanmaktadır.



Symmetric Encryption (Simetrik Şifreleme)

- Simetrik algoritmalar, verileri şifrelemek ve şifresini çözmek için gizli anahtar olarak da adlandırılan aynı önceden paylaşılan anahtarı kullanır. Şifreli iletişim gerçekleşmeden önce gönderen ve alıcı tarafından önceden paylaşılan bir anahtar bilinir.
- Simetrik şifreleme algoritmaları, VPN trafiğinde yaygın olarak kullanılır, çünkü asimetrik şifreleme algoritmalarından daha az CPU kaynağı kullanırlar.
- Simetrik şifreleme algoritmaları kullanılırken, anahtar ne kadar uzun olursa, birisinin anahtarı bulması o kadar uzun sürer. Şifrelemenin güvenli olduğundan emin olmak için en az 128 bit anahtar uzunluğu kullanın.



Simetrik Şifreleme Algoritmaları	Açıklama
Data Encryption Algorithm (DES)	Bu eski bir simetrik şifreleme algoritmasıdır. Akış şifreleme modunda kullanılabilir ancak genellikle 64 bit blok boyutundaki verileri şifreleyerek blok modunda çalışır. Bir akış şifresi bir seferde bir bayt veya bir bit şifreler.
3DES (Triple DES)	Bu DES'in daha yeni bir sürümüdür, ancak DES algoritması işlemini üç kez tekrarlar. Temel algoritma, 35 yıldan fazla bir süredir sahada iyi test edilmiştir. Çok kısa anahtar ömürleri kullanılarak uygulandığında çok güvenilir kabul edilir.
Advanced Encryption Standard (AES)	AES, 3DES'den daha güvenli ve daha verimli bir algoritmadır. Popüler ve önerilen simetrik şifreleme algoritmasıdır. 128, 192 veya 256 bit uzunluğunda veri bloklarını şifrelemek için 128-, 192- veya 256-bit değişken anahtar uzunluğu kullanarak dokuz anahtar ve blok uzunluğu kombinasyonu sunar.
Software-Optimized Encryption (SEAL)	SEAL, DES, 3DES ve AES'e göre daha hızlı bir alternatif simetrik şifreleme algoritmasıdır. 160 bit şifreleme anahtarı kullanır ve CPU üzerinde diğer yazılım tabanlı algoritmalara göre daha düşük bir etkiye sahiptir.
Rivest Ciphers (RC) Series Algorithms	Bu algoritma Ron Rivest tarafından geliştirilmiştir. Çeşitli varyasyonlar geliştirilmiştir, ancak RC4 kullanımda en

	yaygın olanıdır. RC4 bir akış şifresidir ve SSL ve TLS'de web trafiğini güvence altına almak için kullanılır.
--	---

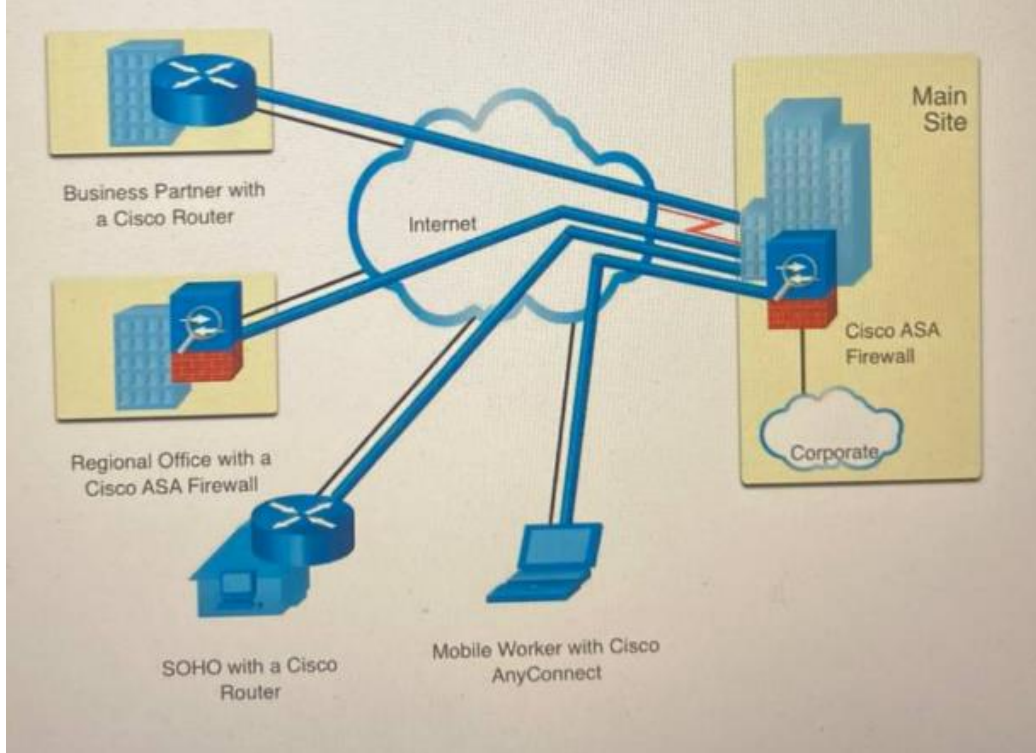
Asymmetric Encryption (Asimetrik Şifreleme)

- Ortak anahtar algoritmaları olarak da adlandırılan asimetrik algoritmalar, şifreleme için kullanılan anahtarın şifresini çözme için kullanılan anahtardan farklı olacak şekilde tasarlanmıştır.
- Asimetrik algoritmalar bir ortak anahtar ve bir özel anahtar kullanır. Şifre çözme için tamamlayıcı eşleştirilmiş anahtar gerektirir. Asimetrik algoritmalar bu işlemi kullanarak gizlilik, kimlik doğrulama ve bütünlük sağlar.
- Her iki tarafın da paylaşılan bir anahtarı olmadığından, çok uzun anahtar uzunlukları kullanılmalıdır. Asimetrik şifreleme, 512 ila 4.096 bit arasındaki anahtar uzunluklarını kullanabilir. Daha kısa anahtar uzunluklarının güvenilir olmadığı düşünülürken, 1.024 bite eşit veya daha büyük anahtar uzunluklarına güvenilebilir.
- Asimetrik anahtar algoritmaları kullanan protokollere örnekler:
 - Internet Key Exchange – Internet Anahtar Değişimi (IKE) - Bu, IPsec VPN'lerin temel bir bileşenidir.
 - Secure Socket Layer (SSL) – Bu artık IETF standart Aktarım Katmanı Güvenliği (TLS) olarak uygulanmaktadır.
 - Secure Shell (SSH) – Bu protokol, ağ aygıtlarına güvenli bir uzaktan erişim bağlantısı sağlar.
 - Pretty Good Privacy (PGP) – Bu bilgisayar programı kriptografik gizlilik ve kimlik doğrulama sağlar. Genellikle e-posta iletişimlerinin güvenliğini artırmak için kullanılır.
- Asimetrik algoritmalar, simetrik algoritmalarından önemli ölçüde daha yavaştır. Tasarımları, aşırı büyük sayıları çarpanlara ayırma veya aşırı büyük sayıdaki ayrık logaritmaları hesaplama gibi hesaplama problemlerine dayanır.
- Yavaş olduklarından, asimetrik algoritmalar genellikle dijital imzalar ve anahtar değişimi gibi düşük hacimli şifreleme mekanizmalarında kullanılır.

Asimetrik Şifreleme Algoritmaları	Key Uzunluğu	Açıklama
Diffie-Hellman (DH)	512, 1024, 2048, 3072, 4096	Diffie-Hellman algoritması, iki tarafın birbirlerine göndermek istedikleri mesajları şifrelemek için kullanabilecekleri bir anahtar üzerinde anlaşmasına izin verir. Bu algoritmanın güvenliği, bir sayıyı belirli bir güce yükseltmenin kolay olduğu, ancak sayı ve sonuç göz önüne alındığında hangi gücün kullanıldığını hesaplamamanın zor olduğu varsayımına bağlıdır.
Digital Signature Standard (DSS) and Digital Signature Algorithm (DSA)	512-1024	DSS, dijital imzalar için algoritma olarak DSA'yı belirtir. DSA, ElGamal imza şemasına dayanan bir ortak anahtar algoritmasıdır. İmza oluşturma hızı RSA'ya benzer, ancak doğrulama için 10 ila 40 kat daha yavaştır.
Rivest, Shamir, and Adleman (RSA)	512 to 2048	RSA, çok büyük sayıları çarpanlarına ayırmanın mevcut zorluklarına dayanan açık anahtarlı kriptografi içindir. Şifrelemenin yanı sıra imzalamaya da uygun olduğu bilinen ilk algoritmadır. Elektronik ticaret protokollerinde yaygın olarak kullanılmaktadır. Ve yeterince uzun anahtarlar ve güncel uygulamaların kullanımı göz önüne alındığında güvenli olduğuna inanılmaktadır.
ElGamal	512-1024	Diffie-Hellman anahtar anlaşmasına dayanan genel anahtar şifrelemesi için asimetrik anahtar şifreleme algoritması. ElGamal sisteminin bir dezavantajı, şifrelenmiş mesajın çok büyük hale gelmesi, orijinal mesajın yaklaşık iki katı büyüklüğünde olması ve bu nedenle sadece gizli anahtarlar gibi küçük mesajlar için kullanılmasıdır.
Elliptical Curve Techniques	160	Eliptik eğri şifreleme, Diffie-Hellman ve ElGamal gibi birçok şifreleme algoritmasını uyarlamak için kullanılabilir. Eliptik eğri şifrelemesinin ana avantajı, tuşların çok daha küçük olabilmesidir.

VPN (Virtual Private Network) Teknolojisi

- Uçtan uca özel ağ bağlantıları oluşturmak için sanal özel ağlar (VPN'ler) kullanılır.
- Bir VPN, bilgileri özel bir ağ içinde taşıdığı için sanaldır, ancak bu bilgi aslında bir genel ağ üzerinden taşınır.
- Bir VPN, trafiğin, genel ağ üzerinden taşınırken verileri gizli tutmak için şifrelenmesi nedeniyle özeldir.



VPN Faydaları

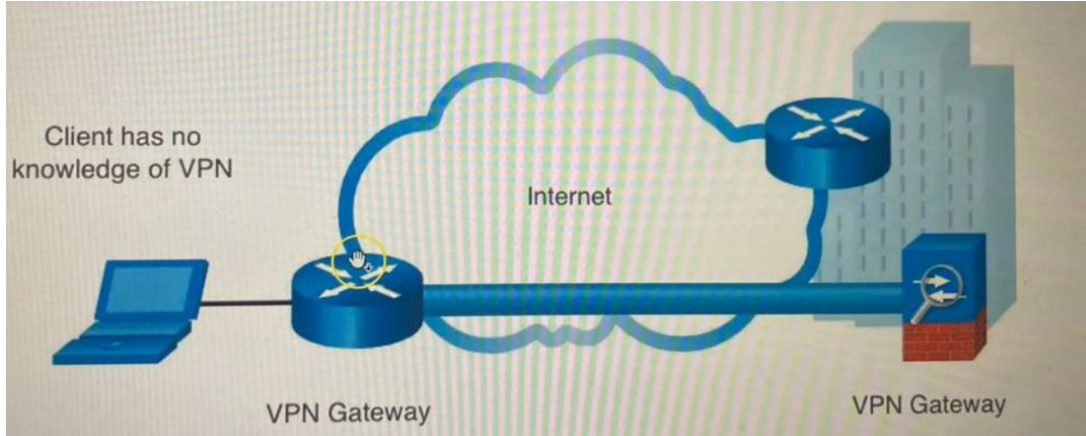
- Modern VPN'ler artık siteler arasındaki ağ trafiğini güvence altına almak için Internet Protocol Security – Internet Protokolü Güvenliği (IPsec) ve Secure Socket Layer – Güvenli Yuva Katmanı (SSL) VPN'leri gibi şifreleme özelliklerini desteklemektedir.
- VPN'lerin başlıca faydaları tabloda gösterilmiştir.

Fayda	Açıklama
-------	----------

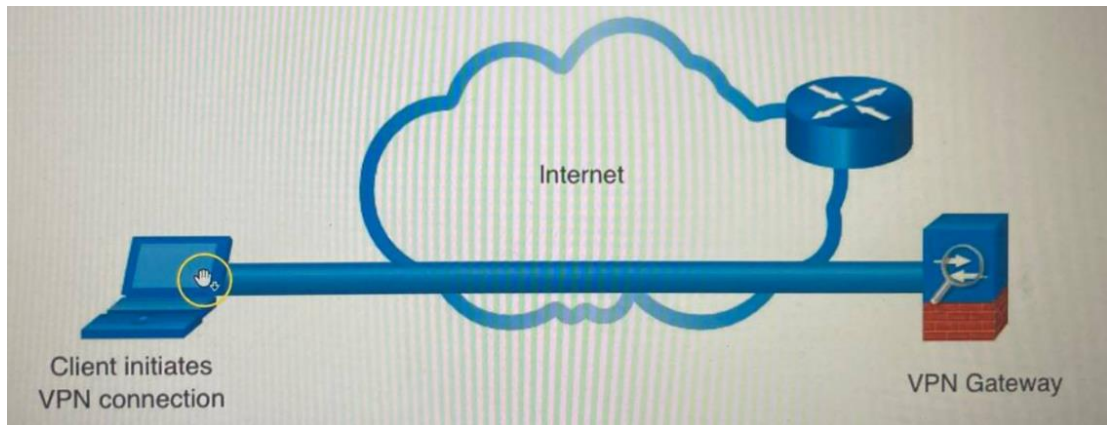
Tasarruf	Kuruluşlar, uzak bağlantı bant genişliğini eşzamanı olarak artırırken, bağlantı maliyetlerini azaltmak için VPN'leri kullanabilir.
Güvenlik	Şifreleme ve kimlik doğrulama protokolleri verileri yetkisiz erişime karşı korur.
Ölçeklenebilirlik	VPN'ler kuruluşların interneti kullanmalarına izin vererek önemli bir altyapı eklemekten yeni kullanıcılar eklemeyi kolaylaştırır.
Uygunluk	VPN'ler, geniş bant teknolojileri de dahil olmak üzere çok çeşitli WAN bağlantı seçeneklerine uygulanabilir. Uzak çalışanlar, şirket ağlarına güvenli erişim sağlamak için bu yüksek hızlı bağlantıları kullanabilir.

Site-to-Site and Remote Access VPNs

Bir siteden siteye VPN, VPN ağ geçitlerinde sonlandırılır. VPN trafiği yalnızca ağ geçitleri arasında şifrelenir. Dahili ana makinelerin VPN kullanıldığına dair hiçbir bilgisi yoktur.



Uzaktan erişim VPN'si, bir istemci ile bir VPN sonlandırma cihazı arasında güvenli bir bağlantı kurmak için dinamik olarak oluşturulur.

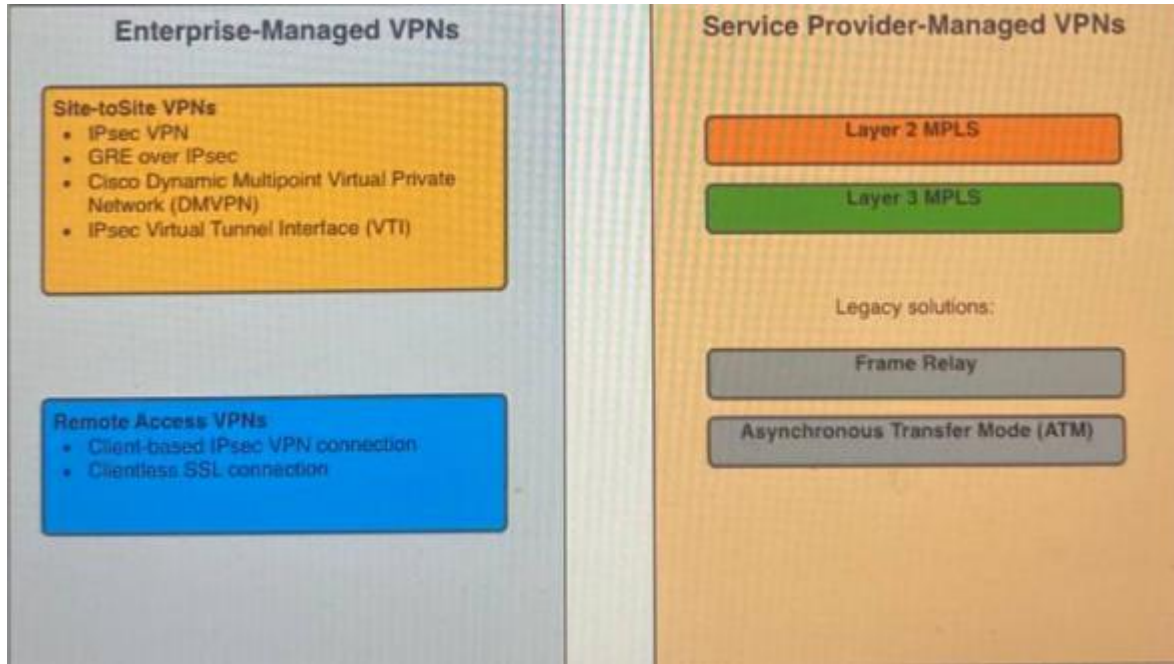


Enterprise and Service Provider VPNs

VPN'ler şu şekilde yönetilebilir ve dağıtılabilir:

Enterprise VPNs – İnternette kurumsal trafiğin güvenliğini sağlamak için ortak bir çözümdür. Siteden siteye ve uzaktan erişim VPN'leri, IPsec ve SSL VPN'leri kullanılarak kuruluş tarafından oluşturulur ve yönetilir.

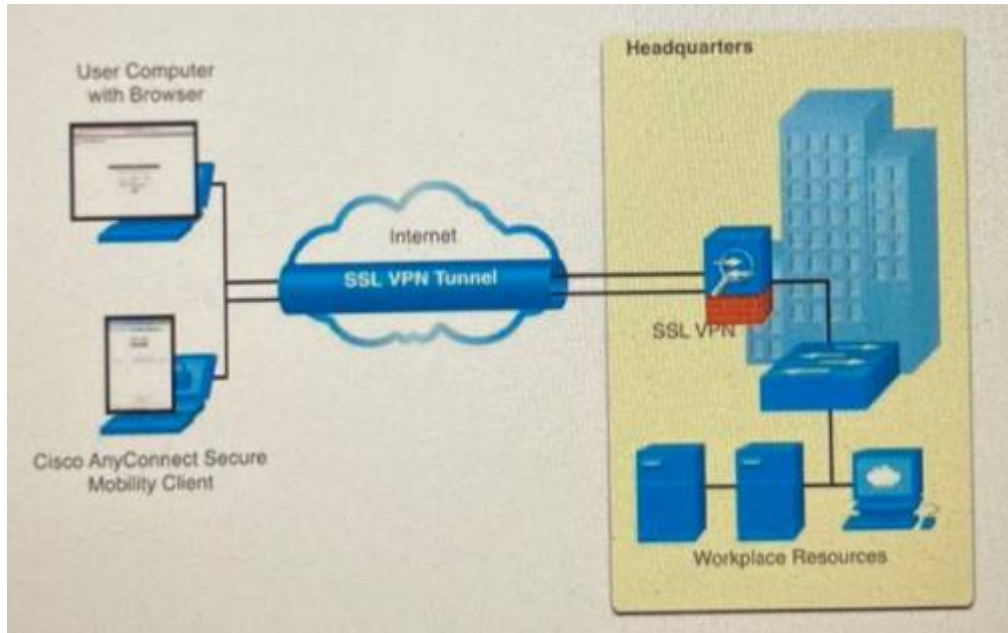
Service Provider VPNs – Servis sağlayıcı ağı tarafından oluşturulur ve yönetilir. Sağlayıcı, bir kuruluşun siteleri arasında güvenilir kanallar oluşturmak ve trafiği diğer müşteri trafiğinden etkili bir şekilde ayırmak için Katman 2 veya Katman 3'teki Multiprotocol Label Switching – Çok Protokollü Etiket Değiştirme'yi (MPLS) kullanır.



VPN Türleri

Remote-Access VPNs

- Uzaktan erişimli VPN'ler, uzak ve mobil kullanıcıların kuruluşa güvenli bir şekilde bağlanmasına olanak tanır.
- Uzaktan erişim VPN'leri genellikle kullanıcı tarafından gerektiğinde dinamik olarak etkinleştirilir ve IPsec veya SSL kullanılarak oluşturulabilir.
- Clientless VPN connection – İstemci olmayan VPN bağlantısı – Bağlantı, bir web tarayıcı SSL bağlantısı kullanılarak güvence altına alınmıştır.
- Client -based VPN connection – İstemci tabanlı VPN bağlantısı – Uzak kullanıcının uç aygıtına Cisco AnyConnect Güvenli Mobilite İstemcisi gibi VPN istemci yazılımı kurulmalıdır.



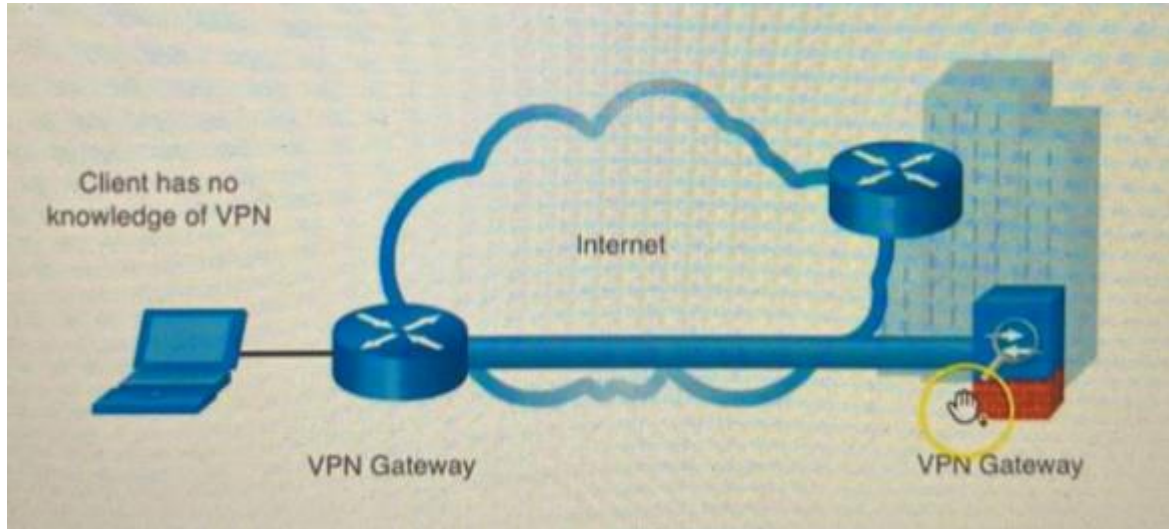
SSL VPNs

SSL, eşlerin kimliğini doğrulamak için ortak anahtar altyapısını ve dijital sertifikaları kullanır. Uygulanan VPN yönteminin türü, kullanıcıların erişim gereksinimlerine ve kuruluşun BT süreçlerine dayanır. Tablo IPsec ve SSL uzaktan erişim dağıtımlarını karşılamaktadır.

Özellik	IPsec	SSL
Desteklenen uygulamalar	Kapsamlı – Tüm IP tabanlı uygulamalar desteklenir.	Sınırlı – Yalnızca web tabanlı uygulamalar ve dosya paylaşımı desteklenir.
Kimlik doğrulama gücü	Güçlü – Paylaşılan anahtarlar veya dijital sertifikalarla iki yönlü kimlik doğrulama kullanır.	Orta – Tek yönlü veya iki yönlü kimlik doğrulaması kullanma.
Şifreleme gücü	Güçlü – 56 bit ile 256 bit arasındaki anahtar uzunluklarını kullanır.	Orta ila güçlü – 40 bit ile 256 bit anahtar uzunlukları ile.
Bağlantı karmaşıklığı	Orta – Ana bilgisayara önceden yüklenmiş bir VPN istemcisi gerektirdiği için.	Düşük – Yalnızca bir ana bilgisayarda bir web tarayıcısı gerektirir.
Bağlantı seçeneği	Sınırlı – Yalnızca belirli yapılandırmalara sahip belirli cihazlar bağlanabilir.	Kapsamlı – Web tarayıcısı olan herhangi bir cihaz bağlanabilir.

Site-to-Site IPsec VPNs

- Site-to-site VPN'ler ağları internet gibi güvenilir olmayan bir ağa bağlar.
- Son ana bilgisayarlar, bir VPN ağ geçidi aracılığıyla normal şifrelenmemiş TCP/IP trafiğini gönderir ve alır.
- VPN ağ geçidi, bir siteden giden trafiği içine alır ve şifreler ve trafiği VPN tüneli üzerinden hedef sitedeki VPN ağ geçidine gönderir. Alıcı VPN ağ geçidi, başlıkları çıkarır, içeriğin şifresini çözer ve paketi özel ağındaki hedef ana bilgisayara doğru aktarır.

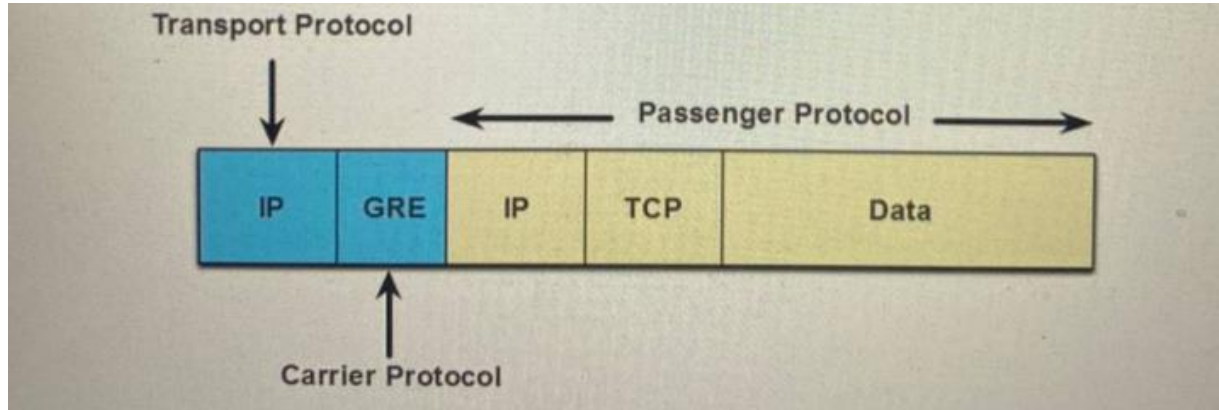


GRE over IPsec (IPsec Üzerinden GRE)

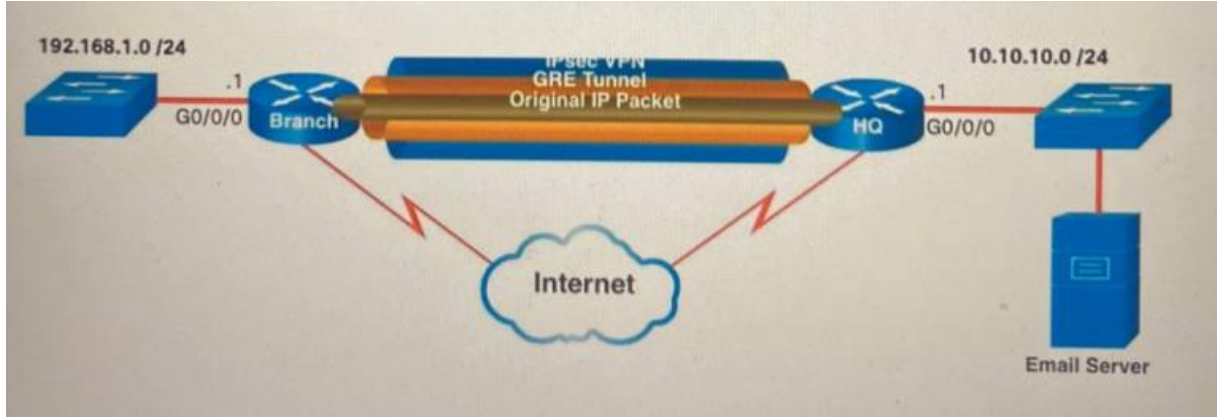
- Generic Routing Encapsulation – Genel Yönlendirme Kapsülleme (GRE) güvenli olmayan bir site-to-site VPN tünel protokoldür.
- GRE tüneli, multicast – çok noktaya yayın ve broadcast – yayın trafiğinin yanı sıra çeşitli ağ katmanlı protokollerini de kapsayabilir.
- GRE varsayılan olarak şifrelemeyi desteklemez; ve bu nedenle güvenli bir VPN tüneli sağlamaz.
- GRE paketi, hedef VPN ağ geçidine güvenli bir şekilde iletmek için bir IPsec paketine kapsüllenebilir.
- Standart IPsec VPN'leri (GRE olmayan) yalnızca unicast – tek noktaya yayın trafiği için güvenli tüneller oluşturabilir.
- GRE'yi IPsec'e kapsüllemek, çok noktaya yayın yönlendirme protokolü güncellemelerinin bir VPN aracılığıyla güvence altına alınmasını sağlar.

GRE'nin IPsec tüneli üzerinden kapsüllemesini tarif etmek için kullanılan terimler yolcu protokolü, taşıyıcı protokolü ve taşıma protokolüdür.

- **Passenger Protocol (Yolcu Protokolü):** Bu, GRE tarafından kapsüllenecek orijinal pakettir. Bir IPv4 veya IPv6 paketi, bir yönlendirme güncellemesi ve daha fazlası olabilir.
- **Carrier Protocol (Taşıyıcı Protokol):** GRE, orijinal yolcu paketini kapsayan taşıyıcı protokolüdür.
- **Transport Protocol (Aktarım Protokolü):** Bu, aslında paketi iletmek için kullanılacak protokoldür. Bu IPv4 veya IPv6 olabilir.



Örneğin, Şube ve Genel Merkezin bir IPsec VPN üzerinden OSPF yönlendirme bilgilerini değiş tokuş etmeleri gerekir. IPsec üzerinden GRE, IPsec VPN üzerinden yönlendirme protokolü trafiğini desteklemek için kullanılır. Özellikle, OSPF paketleri (yani yolcu protokolü) GRE (yani taşıyıcı protokolü) tarafından kapsüllenecek ve daha sonra bir IPsec VPN tüneline kapsüllenecektir.



Dynamic Multipoint VPNs (Dinamik Çok Noktalı VPN)

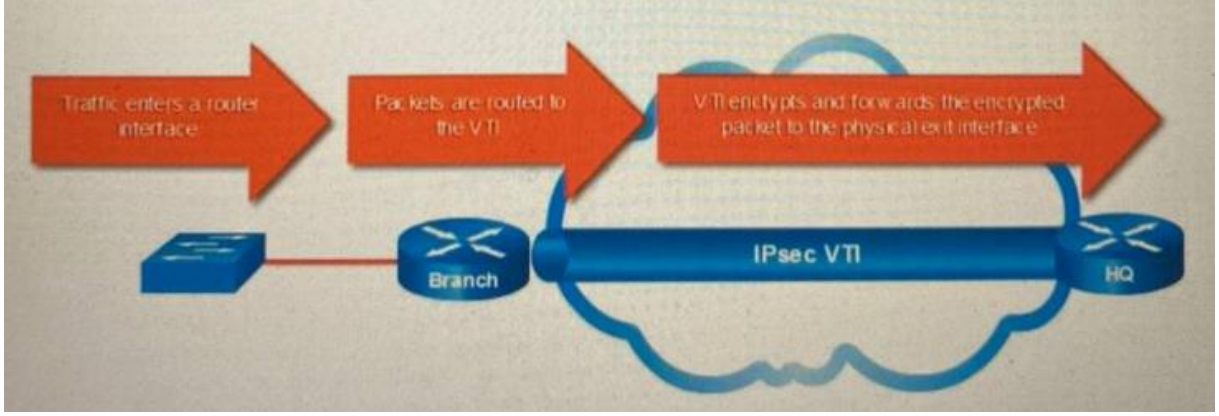
Kuruluş daha fazla site eklediğinde siteden siteye IPsec VPN'leri ve IP üzerinden GRE yeterli değildir. Dinamik Çok Noktalı VPN (DMVPN), birden fazla VPN'i kolay, dinamik ve ölçeklenebilir bir şekilde oluşturmak için bir Cisco yazılım çözümüdür.

- DMVPN, VPN tünel yapılandırmasını basitleştirir ve merkezi bir siteyi şube sitelerine bağlamak için esnek bir seçenek sunar.
- Tam ağ topolojisi oluşturmak için bir hub ve bağlı bileşen yapılandırması kullanır.
- Konuşulan siteler, hub sitesiyle güvenli VPN tünelleri oluşturur.
- Her site, Multipoint Generic Routing Encapsulation – Çok Noktalı Genel Yönlendirme Kapsüllemesi (mGRE) kullanılarak yapılandırılır. MGRE tünel arabirimi, tek bir GRE arabiriminin birden çok IPsec tünellerini dinamik olarak desteklemesini sağlar.
- Spoke siteler de birbirleri hakkında bilgi edinebilir ve alternatif olarak kendi aralarında doğrudan konuşmalı tüneller oluşturabilir.

IPsec Virtual Tunnel Interface

IPsec Sanal Tünel Arabirimi (VTI), birden çok siteyi ve uzaktan erişimi desteklemek için gereken yapılandırma işlemini basitleştirir.

- IPsec VTI yapılandırması, IPsec oturumlarını fiziksel bir arabirimle statik olarak eşlemek yerine sanal bir arabirime uygulanır.
- IPsec VTI, IP tek noktaya yayın ve çok noktaya yayın şifreli trafik gönderme ve alma yeteneğine sahiptir. Bu nedenle, yönlendirme protokolleri GRE tünellerini yapılandırmadan otomatik olarak desteklenir.
- IPsec VTI, siteler arasında veya hub ve bağlı bileşen topolojisinde yapılandırılabilir.



Service Provider MPLS VPNs

Bugün, servis sağlayıcıları ana ağlarında MPLS kullanıyor. Trafik, etiketler kullanılarak MPLS omurgasından iletilir. Trafik güvenlidir, çünkü servis sağlayıcı müşteriler birbirlerinin trafiği görmezler.

- MPLS, istemcilere yönetilen VPN çözümleri sağlayabilir; bu nedenle, müşteri siteleri arasındaki trafiği güvence altına almak servis sağlayıcının sorumluluğundadır.
- Servis sağlayıcılar tarafından desteklenen iki tür MPLS VPN çözümü vardır:

Layer 3 MPLS VPN - Servis sağlayıcı, müşterinin yönlendiricileri ile sağlayıcının yönlendiricileri arasında bir eşleşme oluşturarak müşteri yönlendirmesine katılır.

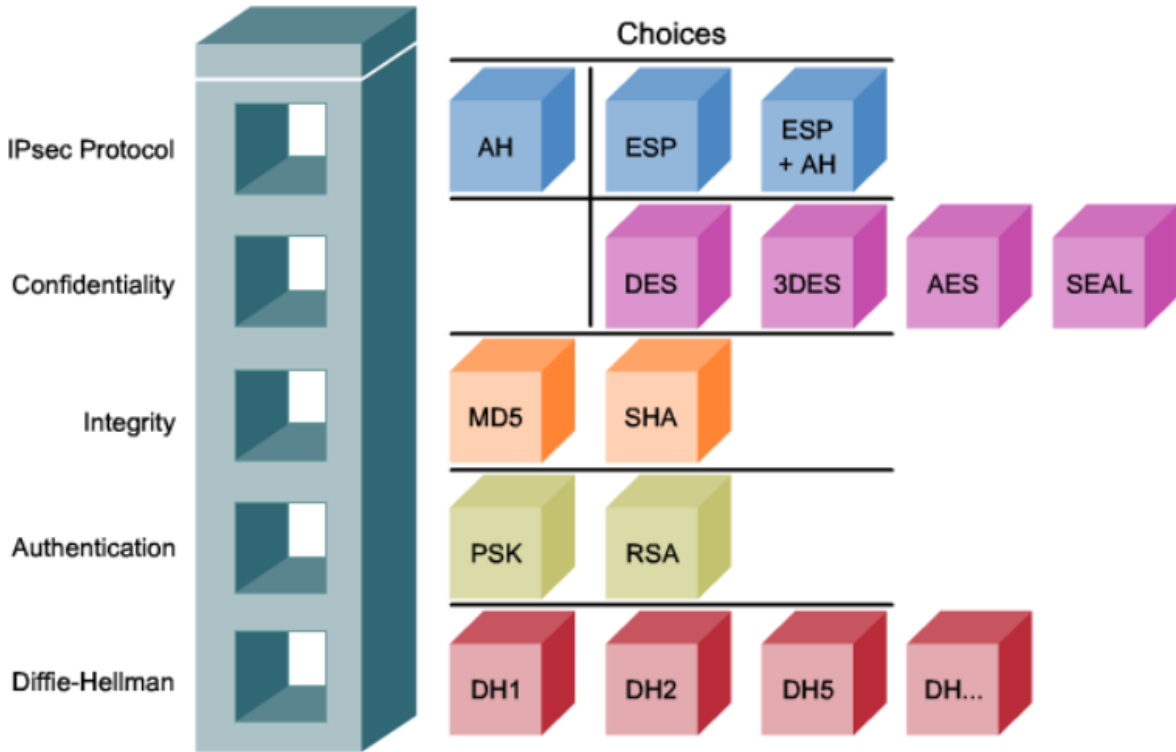
Layer 2 MPLS VPN – Servis sağlayıcı müşteri yönlendirmesine dahil değildir. Bunun yerine, sağlayıcı, MPLS ağı üzerinden bir Ethernet çok işlemli LAN segmentini taklit etmek için bir Virtual Private LAN Service – Sanal Özel LAN Hizmeti (VPLS) dağıtır. Hiçbir yönlendirme söz konusu değildir. Müşterinin yönlendiricileri etkili bir şekilde aynı çok erişimli ağa aittir.

IPsec Teknolojisi

IPsec, bir VPN'nin IP ağlarında nasıl korunabileceğini tanımlayan bir IETF standardıdır. IPsec, kaynak ve hedef arasındaki IP paketlerini korur ve kimlik doğrulaması yapar ve aşağıdaki temel güvenlik işlevlerini sağlar:

- Confidentiality (Gizlilik): Siber suçluların paket içeriğini okumasını önlemek için şifreleme algoritmaları kullanır.
- Integrity (Bütünlük): Paketlerin kaynak ve hedef arasında değiştirilmemesini sağlamak için karma algoritmalar kullanır.
- Origin authentication (Kaynak kimlik doğrulaması): Kaynak ve hedefi doğrulamak için İnternet Anahtar Değişimi (IKE) protokolünü kullanır.
- Diffie-Hellman: Anahtar değişimini güvence altına almak için kullanılır.

IPsec, güvenli iletişim için herhangi bir özel kurala bağlı değildir. IPsec, mevcut IPsec standartlarını güncellemeden yeni güvenlik teknolojilerini kolayca entegre edebilir. Şekilde gösterilen IPsec çerçevesindeki açık yuvalar, benzersiz bir güvenlik ilişkisi (SA-security association) oluşturmak için bu IPsec işlevinin kullanabileceği seçeneklerden herhangi biriyle doldurulabilir.



IPsec Protocol Encapsulation

IPsec protokolü kapsüllemesinin seçilmesi çerçevenin ilk yapı taşıdır.

- IPsec, paketleri Authentication Header – Kimlik Doğrulama Üstbilgisi (AH) veya Encapsulation Security Protocol – Kapsülleme Güvenlik Protokolü (ESP) kullanarak paketler.
- AH ve ESP'nin seçimi, başka hangi yapı taşlarının mevcut olduğunu belirler.
- AH yalnızca gizlilik gerekmediği veya izin verilmediği durumlarda uygundur.
- ESP hem gizlilik hem de kimlik doğrulama sağlar.

Confidentiality (Gizlilik)

Gizlilik derecesi şifreleme algoritmasına ve şifreleme algoritmasında kullanılan anahtarın uzunluğuna bağlıdır. Anahtarı hacklemeye çalışmak için olasılık sayısı, anahtarın uzunluğunun bir fonksiyonudur. Anahtar ne kadar kısa olursa kırmak o kadar kolay olur.

Yukarıdaki şekilde vurgulanan şifreleme algoritmalarının tümü simetrik anahtar şifreleme sistemleridir:

- DES 56 bit anahtar kullanır.
- 3DES, 64 bit blok başına üç bağımsız 56 bit şifreleme anahtarı kullanır.
- AES üç farklı anahtar uzunluğu sunar; 128, 192 ve 256 bit.
- SEAL bir akış şifresidir, yani veri bloklarını şifrelemek yerine verileri sürekli olarak şifreler. SEAL, 160 bit anahtar kullanır.

Integrity (Bütünlük)

- Veri bütünlüğü, verilerin aktarım sırasında değişmediği anlamına gelir.
- Veri bütünlüğünü kanıtlama yöntemi gereklidir.
- Hashed Message Authentication Code – Karma İleti Kimlik Doğrulama Kodu (HMAC), karma değerini kullanarak iletinin bütünlüğünü garanti eden bir veri bütünlüğü algoritmasıdır.
- Message-Digest 5 (MD5), 128 bit paylaşılan gizli anahtar kullanır.
- Secure Hash Algorithm (Güvenli Karma Algoritması - SHA) 160 bit gizli anahtar kullanır.

Authentication (Kimlik Doğrulama)

İki IPsec eş kimlik doğrulama yöntemi vardır:

- **Pre-shared key – Ön paylaşımlı Anahtar (PSK)**, PSK her eşe manuel olarak değer girilir.
- Elle yapılandırması kolaydır.
- İyi ölçeklenmez.
- Her eşte yapılandırılmalıdır.
- **Rivest, Shamir and Adleman (RSA)** – kimlik doğrulama, eşlerin kimliğini doğrulamak için dijital sertifikalar kullanır.
- Tünel güvenli olarak değerlendirilmeden önce her bir eşin karşıt eşini doğrulaması gerekir.

Secure Key Exchange with Diffie-Hellman ile Güvenli Anahtar Değişimi

DH, iki eşin güvenli olmayan bir kanal üzerinden paylaşılan bir gizli anahtar oluşturmalarına olanak tanır.

DH anahtar değişiminin varyasyonları DH grupları olarak belirtilir;

- DH grupları 1, 2 ve 5 artık kullanılmamalıdır.
- DH grupları 14, 15 ve 16, sırayla 2048 bit, 3072 bit ve 4096 bit ile daha büyük anahtar boyutları kullanır.
- 256 bit, 384 bit, 521 bit ve 2048 bit ilgili anahtar boyutlarına sahip 19, 20, 21 ve 24 DH grupları, anahtar üretmek için gereken süreyi azaltan Elliptical Curve Cryptography – Eliptik Eğri Şifrelemesi (ECC) destekler.